



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services



دبلوم امن المعلومات

الفصل 5: أمان البرمجيات والتطبيقات



دبلوم امن المعلومات

● اسم المقرر:

مبادئ التصميم في الأمن السبراني

● رمز المقرر:

ISE125

● الموضوع:

الفصل 5: أمان البرمجيات والتطبيقات



يُصمم قرارات واجهة مستخدم آمنة توازن الوضوح ومنع التسريب.



يطبق مبادئ تطوير البرمجيات الآمنة على مسار تسليم تطبيقي.



يقترح خطة تطوير برمجيات آمنة لنظام المشروع.



يحلل إدارة الأخطاء والتسجيل الآمن بوصفهما جزءاً من التصميم.



يقيّم المفاضلة بين الرصد الأمني وتقليل البيانات المسجلة وحمايتها.



خريطة الفصل

ينتقل الفصل من دمج الأمن في دورة التطوير إلى حماية المدخلات والجلسات والأسرار والاعتماديات.





- ◀ يتكون الفصل من ست وحدات تعلم مستقلة، مدة كل وحدة 60 دقيقة.
- ◀ توزع الوحدات إجمالاً 175 دقيقة لدراسة المحتوى، و85 دقيقة لأنشطة معالجة المعرفة، و60 دقيقة للاختبارات القصيرة والواجب، و40 دقيقة لمرحلة المشروع التراكمي.
- ◀ يبدأ المتعلم كل وحدة بأهدافها وخطتها، وينهيها بنشاط محدد وتقويم ذاتي وخلاصة قبل الانتقال إلى الوحدة التالية.



خطة الوحدات الزمنية (تابع)



الوحدة	المحتوى	الأنشطة	التقويم	المشروع	الإجمالي
الأولى	30 د	15 د	10 د	5 د	60 د
الثانية	30 د	15 د	10 د	5 د	60 د
الثالثة	30 د	15 د	10 د	5 د	60 د
الرابعة	30 د	15 د	10 د	5 د	60 د
الخامسة	30 د	15 د	10 د	5 د	60 د
السادسة	25 د	10 د	10 د	15 د	60 د



- ◀ تطوير البرمجيات الآمنة هو دمج ممارسات الأمن في دورة تطوير البرمجيات بدلاً من إضافتها بعد اكتمال المنتج.
- ◀ وظيفته تقليل الثغرات وخفض أثر استغلالها ومعالجة أسبابها الجذرية.
- ◀ **الوظيفة:** دمج الحماية في التطوير.
- ◀ **المسؤوليات:** تحديد ممارسات أمنية، دمجها في الدورة، معالجة الأسباب الجذرية، توثيق القرارات، تحسين الممارسات باستمرار.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-218 SSDF, OWASP ASVS.
- ◀ **الأجهزة أو الأدوات:** أدوات إدارة الشفرة، مراجعة الشفرة، أدوات الاختبار الأمني.
- ◀ **المخرج:** متطلبات أمنية، خطة تطوير آمن، سجل قرارات، نتائج تحقق.
- ◀ **مثال:** قبل بناء رفع المرفقات، تحدد المنصة التحقق من المدخلات وإدارة الأسرار.
- ◀ تحدد الممارسة أيضاً مسؤولية مراجعة كل مخرج قبل الانتقال إلى المرحلة التالية.
- ◀ فالمتطلب غير القابل للاختبار لا يقدم دليلاً كافياً على الحماية، كما أن نتيجة الاختبار غير المرتبطة بقرار تصميم لا تعالج السبب الجذري.
- ◀ في منصة المواعيد، يراجع الفريق متطلبات المرفقات والأسرار والتفويض قبل بدء التطوير.



تطوير البرمجيات الآمنة (Secure Software Development) (الشكل)

SLIDE 5 · SECURE SOFTWARE DEVELOPMENT

تطوير البرمجيات الآمنة



الأجهزة والأدوات

- أدوات إدارة الشفرة
- مراجعة الشفرة
- أدوات الاختبار الأمني

البروتوكولات والمعايير

- NIST SP 800-218 SSDF
- OWASP ASVS

الوظائف الرئيسية

- دمج الحماية في التطوير
- تحديد ممارسات أمنية
- دمجها في الدورة
- معالجة الأسباب الجذرية
- توثيق القرارات

قبل بناء رفع المرفقات، تحدد المنصة التحقق من المدخلات وإدارة الأسرار.

تطوير البرمجيات الآمنة هو دمج ممارسات الأمن في دورة تطوير البرمجيات بدلاً من إضافتها بعد اكتمال المنتج.



الوحدة الأولى، التخطيط الأمني ومتطلبات التصميم



- أهداف الوحدة: يحدد المتعلم ممارسات تطوير البرمجيات الآمنة، ويحول خطراً إلى متطلب أمني قابل للتحقق، ويحلل حدود الثقة في وظيفة تطبيقية.
- خطة التعلم: يدرس الشرائح 5-11، ثم يقرأ مستند نمذجة التهديدات، وينفذ نشاط ربط الوظيفة بالضابط، ويجب عن التقويم الذاتي.
- زمن الوحدة: 30 دقيقة للمحتوى، و15 دقيقة للنشاط، و10 دقائق للتقويم، و5 دقائق للمشروع.
- معياري الإكمال: يربط المتعلم وظيفة تسجيل الدخول أو عرض المواعيد بتهديد وضابط ووسيلة تحقق مكتوبة.



- ◀ دورة حياة تطوير البرمجيات الآمنة نموذج عمل يدمج ممارسات أمنية قابلة للتكرار في مراحل التطوير.
- ◀ لا يفرض إطار SSDF نموذج تطوير واحداً، بل يتيح دمج الممارسات في النموذج الذي تستخدمه الجهة.
- ◀ **الوظيفة:** جعل الأمن جزءاً من التصميم والتنفيذ والتحقق والصيانة.
- ◀ **المسؤوليات:** إعداد المؤسسة، حماية البرمجيات، إنتاج برمجيات مؤمنة جيداً، الاستجابة للثغرات.
- ◀ **البروتوكولات والمعايير:** SSDF، OWASP ASVS.
- ◀ **الأجهزة أو الأدوات:** مستودع شفرة، مسار بناء واختبار، سجل عيوب، نظام إدارة متطلبات.
- ◀ **المخرج:** خطة دورة آمنة، متطلبات، مخرجات تحقق، سجل معالجة ثغرات.
- ◀ **مثال:** يفحص الفريق الاعتماديات والتهيئة قبل النشر.
- ◀ في منصة المواعيد الطبية الجامعية يراجع الفريق الاعتماديات والتهيئة وحدود الثقة قبل النشر، ويربط كل مرحلة بمخرج تحقق يعاد فحصه بعد أي تغيير على الواجهة أو مسار البناء.



دورة حياة تطوير البرمجيات الآمنة (Secure SDLC) (الشكل)





تبدأ المنصة بتخطيط قصص المستخدم الأمنية وتصنيف البيانات، ثم تنتقل إلى نمذجة التهديد وحدود الثقة في مرحلة التصميم.

أثناء التطوير تطبق التحقق من المدخلات وترميز المخرجات وإدارة الأسرار. وفي الاختبار تراجع الشفرة والاعتماديات والصلاحيات. وينتهي المسار بتسجيل آمن ومراقبة الأحداث وخطة استجابة للحوادث بعد النشر.



متطلبات الأمن (Security Requirements)

- ◀ متطلبات الأمن هي شروط تحدد الضوابط الواجب تحقيقها في التطبيق أو خدمة الويب.
- ◀ تحول هذه المتطلبات هدف الحماية إلى شرط تصميم وتطوير واختبار قابل للتحقق.
- ◀ **الوظيفة:** ربط المخاطر بضوابط قابلة للاختبار.
- ◀ **المسؤوليات:** تحديد الضوابط، ربطها بالمخاطر، جعلها قابلة للاختبار، توثيق الاستثناءات، التحقق من الوفاء بها.
- ◀ **البروتوكولات والمعايير:** OWASP ASVS، NIST SSDF.
- ◀ **الأجهزة أو الأدوات:** أداة إدارة المتطلبات، قائمة تحقق ASVS، نظام تتبع العمل.
- ◀ **المخرج:** قصة مستخدم أمنية، شرط تحقق، معيار قبول أممي.
- ◀ **مثال:** يجب ألا تكشف رسالة فشل الدخول أي بيانات اعتماد خاطئة.
- ◀ في المنصة يتحول خطر تعداد الحسابات إلى متطلب قابل للاختبار: رسالة إخفاق موحدة، مع اختبار أسماء صحيحة وغير صحيحة والتحقق من تقارب زمن الاستجابة.



(الشكل) (Security Requirements) متطلبات الأمن

SLIDE 8 · SECURITY REQUIREMENTS

متطلبات الأمن



البروتوكولات والمعايير

- OWASP ASVS
- NIST SSDF

مثال تطبيقي

- يجب ألا تكشف رسالة فشل الدخول أي بيانات اعتماد خاطئة

الوظائف الرئيسية

- ربط المخاطر بضوابط قابلة للاختبار
- تحديد الضوابط
- ربطها بالمخاطر
- جعلها قابلة للاختبار
- توثيق الاستثناءات

متطلبات الأمن هي شروط تحدد الضوابط الواجب تحقيقها في التطبيق أو خدمة الويب. تحول هذه المتطلبات هدف الحماية إلى شرط تصميم وتطوير واختبار قابل للتحقق.



قصة المستخدم الأمنية (Security User Story)



- ◀ قصة المستخدم الأمنية صياغة مختصرة لمطلب أمني يعبر عن حاجة مستخدم أو جهة، ويرتبط بمعيار قبول قابل للاختبار.
- ◀ تدمج القصة الأمن في تخطيط العمل البرمجي بدلاً من عزله في وثيقة لاحقة.
- ◀ **الوظيفة:** تحويل الضابط إلى مهمة قابلة للتنفيذ والتحقق.
- ◀ **المسؤوليات:** وصف الأصل أو الوظيفة، تحديد التهديد، تحديد الضابط، وضع معيار قبول، تعيين مسؤول التنفيذ والتحقق.
- ◀ **البروتوكولات والمعايير:** SSDF, OWASP ASVS.
- ◀ **الأجهزة أو الأدوات:** لوحة عمل الفريق، أداة تتبع المتطلبات، قائمة تحقق.
- ◀ **المخرج:** قصة مستخدم أمنية مرتبطة بمعيار قبول.
- ◀ **مثال:** يريد المستخدم إنهاء جلسته بعد الخمول لحماية مواعيده.
- ◀ تُربط هذه القصة بمعيار قبول يفحص إنهاء الجلسة بعد خمس عشرة دقيقة من الخمول، ويُعيّن مسؤول التنفيذ وآخر للتحقق قبل إغلاق المهمة.



قصة المستخدم الأمنية (Security User Story) (الشكل)

SLIDE 9 · SECURITY USER STORY

قصة المستخدم الأمنية



الأجهزة والأدوات

- لوحة عمل الفريق
- أداة تتبع المتطلبات
- قائمة تحقق

البروتوكولات والمعايير

- SSDF
- OWASP ASVS

الوظائف الرئيسية

- تحويل الضابط إلى مهمة قابلة للتنفيذ والتحقق
- وصف الأصل أو الوظيفة
- تحديد التهديد
- تحديد الضابط
- وضع معيار قبول

يريد المستخدم انتهاء جلسته بعد الخمول لحماية موارده.

قصة المستخدم الأمنية صياغة مختصرة لمطلب أمني يعبر عن حاجة مستخدم أو جهة، ويرتبط بمعيار قبول قابل للاختبار.



- ◀ نمذجة التهديد للبرمجيات تحليل منظم لمخاطر التصميم والضوابط المطلوبة قبل بناء التطبيق أو أثناء تطويره.
- ◀ تربط بنية التطبيق ومكوناته وواجهاته بالمخاطر المتوقعة والضوابط المناسبة.
- ◀ **الوظيفة:** ربط مكونات التطبيق بقرارات الحماية.
- ◀ **المسؤوليات:** تحديد حدود الثقة، حصر الأصول، تحديد التهديدات، اختيار الضوابط، تحديث النموذج عند التغيير.
- ◀ **البروتوكولات والمعايير:** ASVS V1, NIST SSDF.
- ◀ **الأجهزة أو الأدوات:** مخطط تدفق بيانات، مخطط معماري، سجل مخاطر.
- ◀ **المخرج:** نموذج تهديد، قائمة ضوابط، سجل مخاطر تصميمية.
- ◀ **مثال:** يحلل الفريق مسار رفع مستند قبل تفعيل الميزة.
- ◀ إذا تغيّرت واجهة الرفع أو مسار التخزين يُحدّث نموذج التهديد قبل التفعيل، لأن حدود الثقة والضوابط المطلوبة تتغير مع المكوّن الجديد.



نمذجة التهديد للبرمجيات (Software Threat Modeling) (الشكل)

SLIDE 10 · SOFTWARE THREAT MODELING

نمذجة التهديد للبرمجيات



المخرج المتوقع

- نموذج تهديد
- قائمة ضوابط
- سجل مخاطر تصميمية

الأجهزة والأدوات

- مخطط تدفق بيانات
- مخطط معماري
- سجل مخاطر

الوظائف الرئيسية

- ربط مكونات التطبيق بقرارات الحماية
- تحديد حدود الثقة
- حصر الأصول
- تحديد التهديدات
- اختيار الضوابط

يحلل الفريق مسار رفع مستند قبل تفعيل الميزة

نمذجة التهديد للبرمجيات تحليل منظم لمخاطر التصميم والضوابط المطلوبة قبل بناء التطبيق أو أثناء تطويره

وثيقة نمذجة التهديد وقصص المستخدم الأمنية

المستند: ورقة نمذجة التهديد وقصص المستخدم الأمنية

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم المبرسي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

ورقة نمذجة التهديد وقصص المستخدم الأمنية

منصة مواعيد طبية للعمليات (منشأة سعودية)، جازان، إصدار مراجعة التصميم بتاريخ 2026-03-16

الأصل أو الوظيفة	سيناريو التهديد	قصة المستخدم الأمنية	قرار التصميم والضابط	وسيلة التحقق
تسجيل دخول المستخدم	تعداد الحسابات من خلال اختلاف رسالة الخطأ عند وجود اسم المستخدم أو عدم وجوده.	كمستفيد، أريد رسالة إخطاق موحدة حتى لا يستطيع طرف غير مصرح له معرفة ما إذا كان حسابي موجوداً.	استخدام رسالة موحدة: نغذر تسجيل الدخول، تحقق من البيانات المدخلة: تطبيق تقييد محاولات الدخول بعد خمس محاولات فاشلة متتالية والمصادقة متعددة العوامل.	اختبار أسماء مستخدمين صحيحة وغير صحيحة والتأكد من نطاق الرسالة ورمز الاستجابة تقريباً.
جلسة المستفيد	اختطاف الجلسة من ملف تعريف ارتباط متاج للتصووس البرمجية أو مرسل في سياق غير آمن.	كمستفيد، أريد حماية جلستي حتى لا يتمكن شخص آخر من استخدامها للوصول إلى مواعيدي.	إصدار معرف جلسة عشوائي وتعيين خصائص HttpOnly و Secure و SameSite وإنهاء الجلسة بعد خمس عشرة دقيقة من الخمول.	فحص خصائص ملف تعريف الارتباط واختبار انتهاء الجلسة بعد فترة الخمول.
واجهة برمجة عرض	وصول مستخدم إلى موعد لا يخصه عبر تغيير معرف الموعد في الطلب.	كمستفيد، أريد أن تعرض المنصة مواعيدي فقط حتى تبقى معلوماتي الصحية خاصة.	فرض تحقق تفويض مركزي في الخادم لكل طلب، وربط معرف الموعد بمعرف المستخدم الموثق وعدم الاعتماد على إخفاء عناصر الواجهة.	اختبار حسابين مختلفين مع محاولة طلب معرف موعد لا يخص الحساب الحالي.
رفع مستند صحي	رفع ملف تنفيذي أو ملف باسم مضلل أو ملف يتجاوز حد الحجم.	كمسؤول خدمة، أريد قبول المستندات المعتمدة فقط لمنع إدخال ملفات ضارة إلى المنصة.	قائمة سماح لصيغ PDF و PNG و JPEG، حد حجم خمسة ميغابايت، فحص نوع MIME والبروسبة الفعلية، إعادة تسمية عشوائية، وتخزين معزول غير قابل للتنفيذ.	اختبار امتداد مزدوج ونروسية لا تطابق الامتداد وملف أكبر من الحد وطلب الوصول المباشر للملف.
خدمة الإشعارات	تسريب مفتاح خدمة الرسائل في مستودع الشفرة أو سجل البناء.	كمشغل للنظام، أريد حفظ أسرار التكاميل خارج الشفرة حتى لا تستخدم من طرف غير مصرح له.	تخزين المفاتيح في خزانة أسرار، منح أقل امتيازات، وفحص تلقائي للأسرار قبل دمج الشفرة.	تشغيل فحص الأسرار على طلب دمج تجريبي والتأكد من رفضه عند اكتشاف قيمة حساسة.
اعتمادية خارجية	استغلال ثغرة معروفة في مكتبة مستخدمة لمعالجة الملفات.	كفريق تطوير، نريد معرفة الاعتماديات الضعيفة قبل إدخالها إلى الإصدار.	إنشاء قائمة مكونات برمجية وتشغيل فحص أمان الاعتماديات في مسار التكاميل المستمر واعتماد تحديثات موثقة.	مراجعة تقرير الفحص والتأكد من دمج إصدار يحوي ثغرة عالية الخطورة غير مقبولة.

لا تتضمن الورقة تعليمات استغلال، بل تربط التهديدات المتوقعة بقرارات تصميم قابلة للاختيار.

مستند تعليمي اختراعي، الأسماء والأرقام غير حقيقية

- تقرأ الوثيقة كل أصل أو وظيفة مع التهديد المرتبط بها وقصة المستخدم الأمنية والضابط ووسيلة التحقق.
- في صف تسجيل الدخول، تمنع الرسالة الموحدة تعداد الحسابات.
- وفي صف عرض المواعيد، يفرض التفويض المركزي في الخادم.
- استخدم الجدول لتتبع العلاقة بين التهديد والقرار ودليل التحقق، لا لمجرد سرد الضوابط.



نشاط الوحدة الأولى، من تهديد إلى مطلب



- ◀ خصص 15 دقيقة لتحليل ثلاثة صفوف من مستند نمذجة التهديدات.
- ◀ اختر تسجيل دخول المستفيد، وواجهة برمجة عرض المواعيد، ورفع مستند صحي.
- ◀ اكتب لكل صف الأصل أو الوظيفة، والتهديد، والضابط، ووسيلة تحقق واحدة.
- ◀ بعد ذلك، حدد أي قرار لا يمكن التحقق منه واعد صياغته معيار قبول أمني واضحاً.



لماذا يحدث تحديث نموذج التهديد عند تغير واجهة أو اعتمادية؟



تحقق من قدرتك على الإجابة عن الأسئلة الآتية: ما الفرق بين المتطلب الأمني العام ومعييار القبول القابل للاختبار؟



أضف إلى مشروعك وصف النظام ونطاق الحماية وأصلاً حساساً واحداً.



الخلاصة أن التخطيط الأمني يبدأ بربط الأصل والتهديد والضابط ودليل التحقق.





التحقق من المدخلات (Input Validation)



- ◀ التحقق من المدخلات هو التأكد من أن البيانات الداخلة إلى سير العمل صحيحة التكوين ومتوقعة قبل معالجتها.
- ◀ يمنع انتقال البيانات سيئة التكوين إلى قاعدة البيانات أو المكونات اللاحقة.
- ◀ **الوظيفة:** رفض البيانات غير المقبولة مبكراً.
- ◀ **المسؤوليات:** تحديد مصادر البيانات، تصنيف غير الموثوق، التحقق جانب الخادم، فحص النوع والطول والمدى، رفض الإخفاقات.
- ▶ **البروتوكولات والمعايير:** ASVS V5, OWASP Secure Coding Practices, OWASP Input Validation Cheat Sheet.
- ◀ **الأجهزة أو الأدوات:** مكتبة تحقق مركزية، قواعد مخطط الإدخال، اختبارات وحدات وتكامل.
- ◀ **المخرج:** بيانات مقبولة أو قرار رفض آمن.
- ◀ **مثال:** تقبل المنصة PDF وPNG وJPEG ضمن خمسة ميغابايت.



التحقق من المدخلات (Input Validation) (الشكل)

SLIDE 12 · INPUT VALIDATION

التحقق من المدخلات



البروتوكولات والمعايير

- ASVS V5
- OWASP Secure Coding Practices
- OWASP Input Validation Cheat Sheet

مثال تطبيقي

- تقبل المنصة PDF و PNG و JPEG ضمن خمسة ميجابايت

الوظائف الرئيسية

- رفض البيانات غير المقبولة مبكراً
- تحديد مصادر البيانات
- تصنيف غير الموثوق
- التحقق جانب الخادم
- فحص النوع والطول والمدى

تقبل المنصة PDF و PNG و JPEG ضمن خمسة ميجابايت

التحقق من المدخلات هو التأكد من أن البيانات الداخلة إلى سير العمل صحيحة التكوين ومتوقعة قبل معالجتها



ترميز المخرجات (Output Encoding)

- ◀ ترميز المخرجات هو ترميز البيانات غير الموثوقة عند عرضها أو إدراجها في سياق مخرج محدد.
- ◀ يحد من تفسير البيانات كأوامر أو شيفرة في السياقات المختلفة.
- ◀ **الوظيفة:** حماية سياق العرض أو المعالجة.
- ◀ **المسؤوليات:** تنفيذ الترميز في نظام موثوق، استخدام روتين مختبر، اختيار الترميز حسب السياق، ضبط مجموعة المحارف، معالجة المخرجات غير الموثوقة.
- ▶ **البروتوكولات والمعايير:** ASVS V5, OWASP Secure Coding Practices.
- ◀ **الأجهزة أو الأدوات:** مكتبات ترميز سياقي، قوالب واجهة آمنة، استعلامات معلمة.
- ◀ **المخرج:** مخرج مرمز للسياق المستهدف.
- ◀ **مثال:** يرمز نص الملاحظات قبل عرضه في صفحة المنصة.



ترميز المخرجات (Output Encoding) (الشكل)

SLIDE 13 · OUTPUT ENCODING

ترميز المخرجات



الأجهزة والأدوات

- مكتبات ترميز سياقي
- قوالب واجهة آمنة
- استعلامات معلمة

البروتوكولات والمعايير

- ASVS V5
- OWASP Secure Coding Practices

الوظائف الرئيسية

- حماية سياق العرض أو المعالجة
- تنفيذ الترميز في نظام موثوق
- استخدام روتين مختبر
- اختيار الترميز حسب السياق
- ضبط مجموعة المحارف

يرمز نص الملاحظات قبل عرضه في صفحة المنصة.
ترميز المخرجات هو ترميز البيانات غير الموثوقة عند عرضها أو إدراجها في سياق مخرج محدد. يحد من تفسير البيانات كأوامر أو شيفرة في السياقات المختلفة.

مثال محلول: قرار رفع مستند صحي

المعطيات: تقبل المنصة ملفات PDF و PNG و JPEG، ويجب ألا يتجاوز حجم الملف خمسة ميجابايت.

الخطوات:

1. تحدد قائمة سماح للصيغ الثلاث المعتمدة.
2. تفحص الحجم في الخادم وترفض ما يتجاوز خمسة ميجابايت.
3. تطابق الامتداد مع نوع MIME والترويسة الفعلية.
4. تعيد تسمية الملف بمعرف عشوائي.
5. تخزن الملف في موقع معزول غير قابل للتنفيذ.

الناتج: قرار رفع متعدد الطبقات يمنع الاعتماد على الامتداد الظاهري وحده.





تدفق التحقق من المدخلات وترميز المخرجات



تمر بيانات المستفيد من واجهة الإدخال إلى التحقق على الخادم، حيث تفحص القائمة المسموحة والنوع والحجم والترويسة الفعلية.

بعد قبولها تدخل منطق العمل والتخزين المعزول. وعند عرض البيانات لاحقاً، يطبق ترميز مخرجات يناسب سياق العرض. يحقق هذا التسلسل فصلاً واضحاً بين قبول البيانات ومعالجتها وعرضها.



الوحدة الثانية، حماية المدخلات والمرفقات



- أهداف الوحدة: يطبق المتعلم التحقق الخادمي من المدخلات، ويميز ترميز المخرجات عن ضوابط قاعدة البيانات، ويقترح قرار رفع مستند متعدد الطبقات.
- خطة التعلم: يدرس الشرائح 12-15، ويحلل ورقة العمل، ثم يصوغ قرار رفض آمن لملف مخالف.
- زمن الوحدة: 30 دقيقة للمحتوى، و15 دقيقة للنشاط، و10 دقائق للتقويم، و5 دقائق للمشروع.
- معياري الإكمال: يذكر المتعلم قائمة السماح وحد الحجم وفحص نوع MIME والترويسة الفعلية والتخزين المعزول.



(Session Management) إدارة الجلسات

- ◀ إدارة الجلسات هي حفظ حالة المستخدم وحقوق الوصول عبر طلبات متعددة بين العميل والخادم.
- ◀ تستخدم الجلسة معرفاً يرتبط بحالة المستخدم، ويجب حمايته طوال دورة حياته.
- ◀ **الوظيفة:** المحافظة على تفاعل المستخدم المصرح به.
- ◀ **المسؤوليات:** إنشاء معرف فريد، حماية المعرف، ضبط الانتهاء، الإنهاء عند الخروج، إعادة التحقق للعمليات الحساسة.
- ▶ **ASVS V3, OWASP Session Management Cheat Sheet: البروتوكولات والمعايير**
- ◀ **الأجهزة أو الأدوات:** مخزن جلسات، ملفات تعريف ارتباط بخصائص Secure و HttpOnly و SameSite، خدمة مصادقة.
- ◀ **المخرج:** معرف جلسة وحالة مرتبطة به.
- ◀ **مثال:** تنهي المنصة جلسة المستفيد بعد خمس عشرة دقيقة من الخمول.
- ◀ تحمي هذه الخصائص المعرف من وصول النصوص البرمجية ومن الإرسال في سياق غير آمن، مع إعادة التحقق قبل تعديل بيانات حساسة.



إدارة الجلسات (Session Management) (الشكل)

SLIDE 16 · SESSION MANAGEMENT

إدارة الجلسات



البروتوكولات والمعايير

- ASVS V3
- OWASP Session Management Cheat Sheet

مثال تطبيقي

- تنهي المنصة جلسة المستخدم بعد خمس عشرة دقيقة من الخمول

الوظائف الرئيسية

- المحافظة على تفاعل المستخدم المصرح به
- إنشاء معرف فريد
- حماية المعرف
- ضبط الانتهاء
- الإنهاء عند الخروج

تنهي المنصة جلسة المستخدم بعد خمس عشرة دقيقة من الخمول.
إدارة الجلسات هي حفظ حالة المستخدم وحقوق الوصول عبر طلبات متعددة بين العميل والخادم. تستخدم الجلسة معرفاً يرتبط بحالة المستخدم، ويجب حمايته طوال دورة حياته.



(Secrets Management) إدارة الأسرار

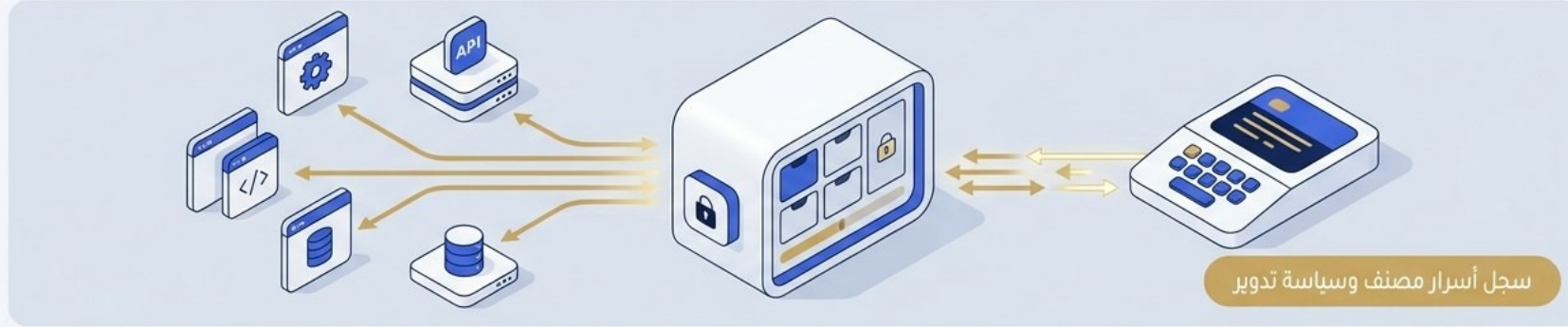
- ◀ إدارة الأسرار هي تنظيم القيم الحساسة اللازمة للتشغيل، مثل كلمات المرور ومفاتيح التطبيق ومفاتيح واجهات البرمجة.
- ◀ تمنع كشف قيم تمنح وصولاً أو قدرة على الاتصال بخدمات حساسة.
- ◀ **الوظيفة:** حماية القيم التشغيلية الحساسة.
- ◀ **المسؤوليات:** منع تضمين السر في الشفرة، تقييد الوصول، تدوير الأسرار، توثيق الملكية، مراقبة الاستخدام، إلغاء السر المكشوف.
- ◀ **البروتوكولات والمعايير:** ASVS V6, NIST SSDF.
- ◀ **الأجهزة أو الأدوات:** مخزن أسرار، خدمة إدارة مفاتيح، متغيرات بيئة مضبوطة، ضوابط وصول.
- ◀ **المخرج:** سجل أسرار مصنف وسياسة تدوير.
- ◀ **مثال:** يحفظ مفتاح خدمة الإشعارات خارج مستودع الشفرة.
- ◀ يُنقل المفتاح إلى خزنة أسرار مع تقييد الوصول وفحص طلبات الدمج، حتى يُرفض أي سر مكتوب في الشفرة قبل دمجها.



إدارة الأسرار (Secrets Management) (الشكل)

SLIDE 17 · SECRETS MANAGEMENT

إدارة الأسرار



الأجهزة والأدوات

- مخزن أسرار
- خدمة إدارة مفاتيح
- متغيرات بيئة مضبوطة
- ضوابط وصول

البروتوكولات والمعايير

- ASVS V6
- NIST SSDF

الوظائف الرئيسية

- حماية القيم التشغيلية الحساسة
- منع تضمين السر في الشفرة
- تقييد الوصول
- تدوير الأسرار
- توثيق الملكية

يحفظ مفتاح خدمة الإشعارات خارج مستودع الشفرة

إدارة الأسرار هي تنظيم القيم الحساسة اللازمة للتشغيل، مثل كلمات المرور ومفاتيح التطبيق ومفاتيح واجهات البرمجة



- ◀ إدارة مفاتيح التطبيق تنظيم إنشاء مفاتيح التشفير وتخزينها واستخدامها وتدويرها وإلغائها داخل التطبيق.
- ◀ تدعم سرية البيانات وتكاملها من دون جعل المفتاح نقطة فشل مكشوفة.
- ◀ **الوظيفة:** حماية دورة حياة المفتاح.
- ◀ **المسؤوليات:** تحديد مالك المفتاح، تقييد الوصول، فصل مفاتيح البيئات، التدوير، الإلغاء، توثيق الاستخدام.
- ▶ **المعايير:** ASVS V6, NIST SSDF, Anderson 4.7 Managing encryption keys.
- ◀ **الأجهزة أو الأدوات:** خدمة إدارة مفاتيح، مخزن أسرار، وحدات تشفير، خدمات سحابية مخصصة.
- ◀ **المخرج:** سجل مفاتيح وسياسة تدوير.
- ◀ **مثال:** تستخدم المنصة مفتاحاً منفصلاً لكل بيئة تطوير واختبار وإنتاج.
- ◀ يُحدّد مالك لكل مفتاح مع سياسة تدوير وإلغاء، حتى لا يبقى المفتاح نقطة فشل مكشوفة داخل المستودع أو مشتركة بين البيئات.



(الشكل) (Application Key Management) إدارة مفاتيح التطبيق

SLIDE 18 · APPLICATION KEY MANAGEMENT

إدارة مفاتيح التطبيق



المخرج المتوقع

- سجل مفاتيح وسياسة تدوير

الأجهزة والأدوات

- خدمة إدارة مفاتيح
- مخزن أسرار
- وحدات تشفير
- خدمات سحابية مخصصة

الوظائف الرئيسية

- حماية دورة حياة المفتاح
- تحديد مالك المفتاح
- تقييد الوصول
- فصل مفاتيح البيئات
- التدوير

تستخدم المنصة مفتاحاً منفصلاً لكل بيئة تطوير واختبار وإنتاج

إدارة مفاتيح التطبيق تنظم إنشاء مفاتيح التشفير وتخزينها واستخدامها وتدويرها وإلغائها داخل التطبيق.



(Dependency Security) أمان الاعتماديات

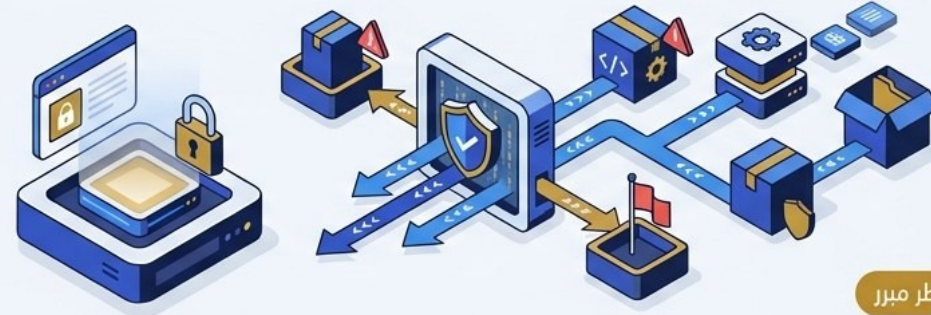
- ◀ أمان الاعتماديات هو إدارة مخاطر المكتبات والحزم والمكونات الخارجية المستخدمة في التطبيق.
- ◀ يقلل احتمال إدخال مكونات ضعيفة أو قديمة أو مجهولة المصدر إلى المنتج.
- ◀ **الوظيفة:** ضبط مخاطر المكونات الخارجية.
- ◀ **المسؤوليات:** حصر الإصدارات، متابعة التحديثات، تقييم المصدر، إزالة غير الضروري، مراجعة أثر التحديث، توثيق الاستثناءات.
- ◀ **البروتوكولات والمعايير:** OWASP Top 10 A06:2021، NIST SSDF.
- ◀ **الأجهزة أو الأدوات:** ملف بيان الاعتماديات، أداة فحص مكونات، مستودع حزم موثوق، سجل مكونات.
- ◀ **المخرج:** قائمة مكونات وقرار تحديث أو قبول خطر مبرر.
- ◀ **مثال:** يحتفظ الفريق بإصدارات مكتبات الواجهة والخادم في قائمة مكونات.
- ◀ قبل دمج مكتبة معالجة ملفات يُراجع تقرير الفحص، ويُمنع إصدار يحوي ثغرة عالية الخطورة غير مقبولة، مع توثيق أي استثناء.



أمان الاعتماديات (Dependency Security) (الشكل)

SLIDE 19 • DEPENDENCY SECURITY

أمان الاعتماديات



مثال تطبيقي

- يحتفظ الفريق بإصدارات مكتبات الواجهة والخادم في قائمة مكونات

المخرج المتوقع

- قائمة مكونات وقرار تحديث أو قبول خطر مبرر

الوظائف الرئيسية

- ضبط مخاطر المكونات الخارجية
- حصر الإصدارات
- متابعة التحديثات
- تقييم المصدر
- إزالة غير الضروري

يحتفظ الفريق بإصدارات مكتبات الواجهة والخادم في قائمة مكونات.

أمان الاعتماديات هو إدارة مخاطر المكتبات والحزم والمكونات الخارجية المستخدمة في التطبيق. يقلل احتمال إدخال مكونات ضعيفة أو قديمة أو مجهولة المصدر إلى المنتج.



- ◀ سلسلة توريد البرمجيات تشمل المصادر والمكونات والبناء والتحديثات التي تسهم في إنتاج البرمجيات ونشرها.
- ◀ تحمي نزاهة الشفرة والبنية ومسارات البناء والتحديثات.
- ◀ **الوظيفة:** ضمان قابلية تتبع المكونات والبناء.
- ◀ **المسؤوليات:** التحقق من مصدر المكونات، حماية مسار البناء، التحقق من النزاهة، مراجعة التحديثات، إدارة الوصول إلى النشر.
- ◀ **البروتوكولات والمعايير:** OWASP Top 10 A08:2021, NIST SSDF.
- ◀ **الأجهزة أو الأدوات:** مستودع شفرة، خدمة بناء، مستودع حزم، تحقق نزاهة، ضوابط CI/CD.
- ◀ **المخرج:** سجل مكونات ومخرج بناء قابل للتتبع.
- ◀ **مثال:** يتحقق الفريق من سلامة تحديث قبل إدخاله إلى مسار البناء.
- ◀ يُقَيّد من يملك صلاحية النشر، ويُحفظ مخرج البناء قابلاً للتتبع، حتى لا يدخل مكوّن مجهول المصدر إلى بيئة التشغيل.



سلسلة توريد البرمجيات (Software Supply Chain) (الشكل)

SLIDE 20 · SOFTWARE SUPPLY CHAIN

سلسلة توريد البرمجيات



البروتوكولات والمعايير

- OWASP Top 10 A08:2021
- NIST SSDF

مثال تطبيقي

- يتحقق الفريق من سلامة تحديث قبل إدخاله إلى مسار البناء

الوظائف الرئيسية

- ضمان قابلية تتبع المكونات والبناء
- التحقق من مصدر المكونات
- حماية مسار البناء
- التحقق من النزاهة
- مراجعة التحديثات

يتحقق الفريق من سلامة تحديث قبل إدخاله إلى مسار البناء

سلسلة توريد البرمجيات تشمل المصادر والمكونات والبناء والتحديثات التي تسهم في إنتاج البرمجيات ونشرها. تحمي نزاهة الشفرة والبنية ومسارات البناء والتحديثات



- ◀ خصص 15 دقيقة لقراءة السيناريو الثاني في ورقة العمل.
- ◀ حدد سبب عدم كفاية امتداد الملف الظاهري، ثم رتب خمسة ضوابط من القبول حتى التخزين.
- ◀ اختبر قرارك ذاتياً: هل يتم التحقق على الخادم؟
- ◀ هل يطابق نوع MIME والترويسة الفعلية الامتداد؟
- ◀ هل يعاد تسمية الملف ويخزن في موقع معزول غير قابل للتنفيذ؟
- ◀ أضف القرار إلى خطة مشروعك.



OWASP Top 10

- ◀ OWASP Top 10 وثيقة توعوية للمطورين وأمن تطبيقات الويب، وتمثل توافقاً واسعاً حول المخاطر المهمة.
- ◀ لا تحل محل تحليل المخاطر أو معيار تحقق شامل، لكنها تساعد في ربط فئات المخاطر بقرارات التصميم.
- ◀ **الوظيفة:** دعم الوعي وربط المخاطر بالضوابط.
- ◀ **المسؤوليات:** استخدام الفئات للتوعية، ربط كل فئة بضوابط، مراجعة الإصدار المعتمد، عدم اختزال برنامج الأمن فيها.
- ◀ **البروتوكولات والمعايير:** OWASP ASVS، OWASP Top 10:2021.
- ◀ **الأجهزة أو الأدوات:** قائمة تحقق مخاطر، متطلبات ASVS، أدوات مراجعة واختبار.
- ◀ **المخرج:** خريطة مخاطر مقابل ضوابط.
- ◀ **مثال:** ترتبط A03:2021 Injection بالتحقق من المدخلات وترميز المخرجات.



OWASP Top 10 (الشكل)

SLIDE 21 • OWASP TOP 10

OWASP Top 10



الأجهزة والأدوات

- قائمة تحقق مخاطر
- متطلبات ASVS
- أدوات مراجعة واختبار

البروتوكولات والمعايير

- OWASP Top 10:2021
- OWASP ASVS

الوظائف الرئيسية

- دعم الوعي وربط المخاطر بالضوابط
- استخدام الفئات للتوعية
- ربط كل فئة بضوابط
- مراجعة الإصدار المعتمد
- عدم اختزال برنامج الأمن فيها

ترتبط Injection A03:2021 بالتحقق من المدخلات وترميز المخرجات.

OWASP Top 10 وثيقة توعية للمطورين وأمن تطبيقات الويب، وتمثل توافقاً واسعاً حول المخاطر المهمة.



فئات مختارة للتطبيق من OWASP Top 10:2021 وقرار التصميم الوقائي

فئة الخطر	قرار التصميم الوقائي	وسيلة تحقق
A01:2021 Broken Access Control	تفويض مركزي لكل طلب في الخادم	اختبار حسابين وطلب مورد غير مصرح
A03:2021 Injection	تحقق خادمي وترميز سياقي	اختبار مدخلات غير متوقعة
A06:2021 Vulnerable and Outdated Components	حصر الإصدارات وفحص الاعتماديات	مراجعة تقرير الفحص
A08:2021 Software and Data Integrity Failures	حماية مسار البناء والتحقق من التحديث	مراجعة دليل النزاهة

يستخدم الجدول لتحديد القرار والتحقق منه، وليس لاستبدال تحليل مخاطر التطبيق وسياقه.



الوحدة الثالثة، الجلسات والأسرار وسلسلة التوريد



- أهداف الوحدة: يطبق المتعلم حماية دورة حياة الجلسة، ويقترح إدارة مناسبة للأسرار، ويحلل قراراً يتعلق باعتمادية خارجية أو مسار بناء.
- خطة التعلم: يدرس الشرائح 16-22، ثم يحلل صف الجلسة وصف خدمة الإشعارات وصف الاعتمادية الخارجية في مستند التهديدات.
- زمن الوحدة: 30 دقيقة للمحتوى، و15 دقيقة للنشاط، و10 دقائق للتقويم، و5 دقائق للمشروع.
- معياري الإكمال: يحدد المتعلم الضابط ودليل التحقق لكل من الجلسة والسر والاعتمادية.



- ◀ أمان واجهات البرمجة هو تطبيق ضوابط الأمن على الواجهات والخدمات التي تتبادل الطلبات والبيانات مع عملاء أو خدمات أخرى.
- ◀ لا يكفي إخفاء الوظيفة في واجهة المستخدم، لأن الخادم يجب أن يتحقق من كل طلب.
- ◀ **الوظيفة:** حماية الوظائف والبيانات المتاحة عبر الواجهة.
- ◀ **المسؤوليات:** مصادقة العميل، تفويض العملية، التحقق من المدخلات، حماية الأسرار، ضبط الأخطاء، مراقبة الأحداث.
- ▶ **البروتوكولات والمعايير:** ASVS V13, OWASP Secure Coding Practices.
- ◀ **الأجهزة أو الأدوات:** بوابة API، خدمة هوية، سجلات تطبيق، ضوابط معدل طلبات، أدوات اختبار.
- ◀ **المخرج:** طلب متحقق منه واستجابة مرمزة وقرار تفويض.
- ◀ **مثال:** يمنع الخادم عرض موعد لا يخص الحساب الحالي.
- ◀ لا يكفي إخفاء زر في الواجهة.
- ◀ كل طلب إلى واجهة عرض المواعيد يُتَحقق منه في الخادم ويربط المورد بالمستخدم الموثق قبل الاستجابة.



أمان واجهات البرمجة (API Security) (الشكل)

SLIDE 23 · API SECURITY

أمان واجهات البرمجة



مثال تطبيقي

- يمنع الخادم عرض موعد لا يخص الحساب الحالي

المخرج المتوقع

- طلب متحقق منه واستجابة مرمزة وقرار تفويض

يمنع الخادم عرض موعد لا يخص الحساب الحالي

الوظائف الرئيسية

- حماية الوظائف والبيانات المتاحة عبر الواجهة
- مصادقة العميل
- تفويض العملية
- التحقق من المدخلات
- حماية الأسرار

أمان واجهات البرمجة هو تطبيق ضوابط الأمن على الواجهات والخدمات التي تتبادل الطلبات والبيانات مع عملاء أو خدمات أخرى



- ◀ خصص 15 دقيقة لمقارنة ثلاثة قرارات.
- ◀ للجلسة، تحقق من خصائص ملف تعريف الارتباط Secure و HttpOnly و SameSite ومن انتهاء الخمول بعد خمس عشرة دقيقة.
- ◀ لخدمة الإشعارات، حدد سبب نقل المفتاح إلى خزنة أسرار.
- ◀ للاعتمادية، بين دليل منع دمج إصدار يحوي ثغرة عالية الخطورة غير مقبولة.
- ◀ أضف أحد القرارات إلى سجل تصميم مشروعك.



- ◀ تصميم واجهات المستخدم الآمنة هو تصميم الرسائل والخطوات والتفاعل بما يدعم الاستخدام الصحيح ولا يكشف معلومات حساسة.
- ◀ يوازن بين وضوح الإجراءات وحماية العمليات المهمة.
- ◀ **الوظيفة:** تقليل الأخطاء البشرية والتسريب المعلوماتي.
- ◀ **المسؤوليات:** توضيح الإجراءات، تقليل كشف المعلومات، تقديم تغذية راجعة مناسبة، حماية العمليات الحساسة، مراعاة قابلية الاستخدام.
- ◀ **البروتوكولات والمعايير:** ASVS V1, ASVS V2, ASVS V7.
- ◀ **الأجهزة أو الأدوات:** نماذج واجهات تعليمية، اختبارات قابلية استخدام، قائمة تحقق رسائل الخطأ.
- ◀ **المخرج:** تصميم شاشة ونص رسالة وقرار واجهة موثق.
- ◀ **مثال:** تعرض المنصة رسالة موحدة عند فشل الدخول.
- ◀ توضح الرسالة الإجراء التالي للمستخدم من دون كشف وجود الحساب أو اسم الخادم أو أي تفصيل داخلي يساعد على الاستطلاع.

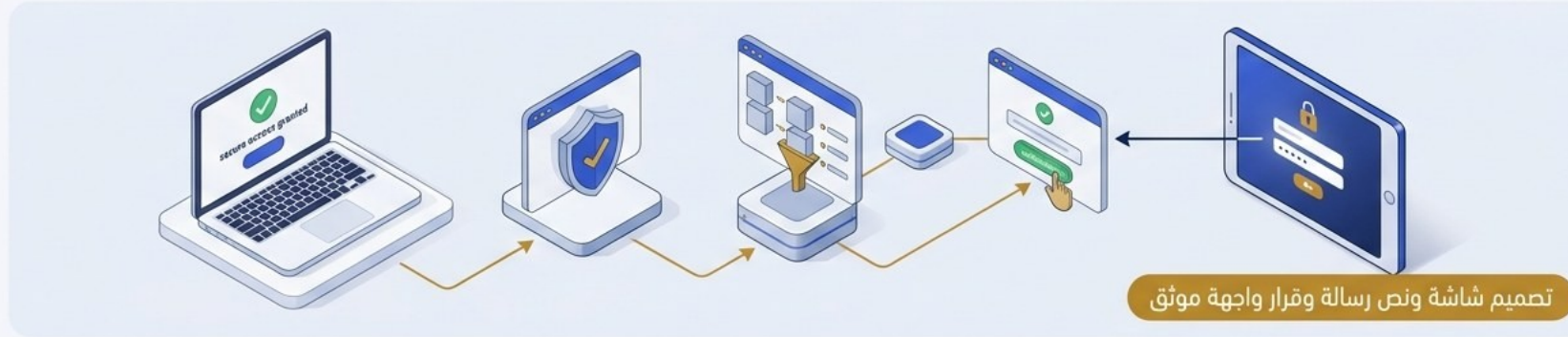


تصميم واجهات المستخدم الآمنة (Secure User Interface Design) (الشكل)



SLIDE 24 · SECURE USER INTERFACE DESIGN

تصميم واجهات المستخدم الآمنة



البروتوكولات والمعايير

- ASVS V1
- ASVS V2
- ASVS V7

مثال تطبيقي

- تعرض المنصة رسالة موحدة عند فشل الدخول

الوظائف الرئيسية

- تقليل الأخطاء البشرية والتسريب المعلوماتي
- توضيح الإجراء
- تقليل كشف المعلومات
- تقديم تغذية راجعة مناسبة
- حماية العمليات الحساسة

تعرض المنصة رسالة موحدة عند فشل الدخول.

تصميم واجهات المستخدم الآمنة هو تصميم الرسائل والخطوات والتفاعل بما يدعم الاستخدام الصحيح ولا يكشف معلومات حساسة. يوازن بين وضوح الإجراء وحماية العمليات المهمة.



- ◀ تجربة المستخدم والأمن تعني موازنة الضوابط مع قدرة المستخدم على فهم الإجراء وتنفيذه بطريقة صحيحة.
- ◀ لا ينبغي أن يدفع الغموض أو التعقيد غير الضروري المستخدم إلى تجاوز الحماية.
- ◀ **الوظيفة:** دعم السلوك الآمن القابل للتنفيذ.
- ◀ **المسؤوليات:** تصميم تدفق واضح، دعم الاسترداد الآمن، مراعاة العمليات الحساسة، اختبار قابلية الاستخدام، تقليل العبء الغامض.
- ▶ **البروتوكولات والمعايير:** Anderson Chapter 3, OWASP ASVS.
- ◀ **الأجهزة أو الأدوات:** اختبار واجهات، سيناريوهات مستخدم، مراجعة تصميم.
- ◀ **المخرج:** قرار تصميم واجهة أو نتيجة اختبار استخدام.
- ◀ **مثال:** يطلب عامل ثانٍ قبل تعديل بيانات حساسة.
- ◀ تبقى خطوات الدخول اليومية واضحة وقابلة للتنفيذ، حتى لا يتجاوز المستخدم الحماية بسبب غموض أو تعقيد غير لازم في المهام منخفضة الخطورة.

تجربة المستخدم والأمن (Usability and Security) (الشكل)

SLIDE 25 · USABILITY AND SECURITY

تجربة المستخدم والأمن



الأجهزة والأدوات

- اختبار واجهات
- سيناريوهات مستخدم
- مراجعة تصميم

البروتوكولات والمعايير

- Anderson Chapter 3
- OWASP ASVS

يطلب عامل ثانٍ قبل تعديل بيانات حساسة

الوظائف الرئيسية

- دعم السلوك الآمن القابل للتنفيذ
- تصميم تدفق واضح
- دعم الاسترداد الآمن
- مراعاة العمليات الحساسة
- اختبار قابلية الاستخدام

تجربة المستخدم والأمن تعني موازنة الضوابط مع قدرة المستخدم على فهم الإجراء وتنفيذه بطريقة صحيحة.



رسائل الخطأ الآمنة (Secure Error Messages)

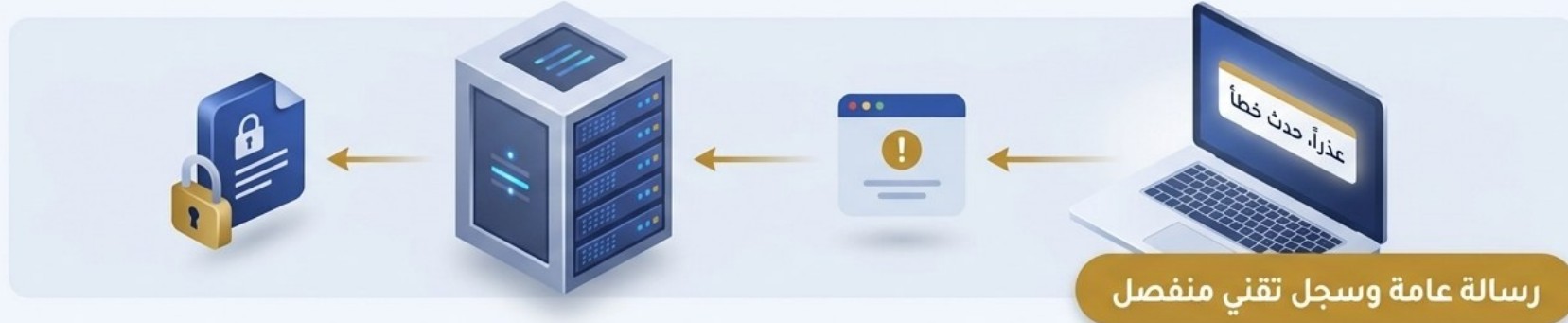
- ◀ رسائل الخطأ الآمنة رسائل للمستخدم تعالج الفشل من دون كشف تفاصيل تقنية أو معلومات حساسة.
- ◀ تمنع الرسائل المكشوفة دعم الاستطلاع أو كشف حالة الحساب أو البنية الداخلية.
- ◀ **الوظيفة:** إبلاغ المستخدم مع تقليل التسريب.
- ◀ **المسؤوليات:** استخدام معالجة مركزية، عرض رسالة عامة، حفظ تفاصيل للدعم في سجل محمي، منع عرض أثر التنفيذ، اختبار مسارات الخطأ.
- ▶ **البروتوكولات والمعايير:** ASVS V7, OWASP Error Handling Cheat Sheet, OWASP Developer Guide.
- ◀ **الأجهزة أو الأدوات:** معالج أخطاء مركزي، صفحات خطأ مخصصة، سجل تطبيق محمي.
- ◀ **المخرج:** رسالة عامة وسجل تقني منفصل.
- ◀ **مثال:** تظهر رسالة تعذر إتمام الطلب حالياً بدلاً من اسم قاعدة البيانات.
- ◀ تُحفظ تفاصيل الاستثناء في سجل محمي للفريق المخول، وتُختبر مسارات الخطأ حتى لا يظهر أثر التنفيذ أو معرف الجلسة للمستخدم.



رسائل الخطأ الآمنة (Secure Error Messages) (الشكل)

SLIDE 26 • SECURE ERROR MESSAGES

رسائل الخطأ الآمنة



المخرج المتوقع

- رسالة عامة وسجل تقني منفصل

الأجهزة والأدوات

- معالج أخطاء مركزي
- صفحات خطأ مخصصة
- سجل تطبيق محمي

الوظائف الرئيسية

- إبلاغ المستخدم مع تقليل التسريب
- استخدام معالجة مركزية
- عرض رسالة عامة
- حفظ تفاصيل للدعم في سجل محمي
- منع عرض أثر التنفيذ

تظهر رسالة تعذر إتمام الطلب حالياً بدلاً من اسم قاعدة البيانات.

رسائل الخطأ الآمنة رسائل للمستخدم. تعالج الفشل من دون كشف تفاصيل تقنية أو معلومات حساسة.



- ◀ رسالة مثل «المستخدم غير موجود» تكشف أن الاسم غير مسجل، ورسالة مختلفة لكلمة المرور غير الصحيحة تكشف وجود الحساب.
- ◀ القرار الآمن هو الرسالة الموحدة: «تعذر تسجيل الدخول، تحقق من البيانات المدخلة».
- ◀ يسجل النظام نوع الحدث والطابع الزمني ومعرف طلب عشوائي فقط.
- ◀ يضاف تقييد للمحاولات والمصادقة متعددة العوامل للعمليات الحساسة.



إعادة تعيين كلمة المرور (Password Recovery)



- ◀ إعادة تعيين كلمة المرور مسار استرداد بيانات الاعتماد عند فقد المستخدم وسيلة الدخول أو حاجته إلى تغييرها.
- ◀ يجب أن يعيد الوصول المشروع مع مقاومة انتحال الهوية وعدم كشف وجود الحساب.
- ◀ **الوظيفة:** استعادة الوصول بطريقة مضبوطة.
- ◀ **المسؤوليات:** التحقق من الهوية، حماية رمز الاسترداد، ضبط المهلة، إبطال الجلسات عند الحاجة، منع كشف الحساب، تسجيل الحدث.
- ▶ **البروتوكولات والمعايير:** ASVS V2.5, OWASP Authentication Cheat Sheet.
- ◀ **الأجهزة أو الأدوات:** خدمة هوية، قناة تحقق، رموز مؤقتة، سجل أمني.
- ◀ **المخرج:** طلب استرداد ورمز محدود العمر وسجل حدث.
- ◀ **مثال:** تستجيب المنصة بالرسالة نفسها سواء وجد الحساب أم لم يوجد.
- ◀ يُحمى رمز الاسترداد بمهلة قصيرة، وتُبطل الجلسات عند الحاجة، ويُسجّل الحدث من دون كشف وجود الحساب أو إرسال كلمة المرور الأصلية.



إعادة تعيين كلمة المرور (Password Recovery) (الشكل)

SLIDE 28 · PASSWORD RECOVERY

إعادة تعيين كلمة المرور



البروتوكولات والمعايير

- ASVS V2.5
- OWASP Authentication Cheat Sheet

مثال تطبيقي

- تستجيب المنصة بالرسالة نفسها سواء وجد الحساب أم لم يوجد

الوظائف الرئيسية

- استعادة الوصول بطريقة مضبوطة
- التحقق من الهوية
- حماية رمز الاسترداد
- ضبط المهلة
- إبطال الجلسات عند الحاجة

إعادة تعيين كلمة المرور مسار استرداد بيانات الاعتماد عند فقد المستخدم وسيلة الدخول أو حاجته إلى تغييرها



الوحدة الرابعة، الواجهة الآمنة وإدارة الأخطاء



- أهداف الوحدة: يصمم المتعلم رسالة إخفاق لا تكشف وجود الحساب، ويفرق بين المصادقة والتفويض في واجهة برمجة، ويقترح مساراً آمناً لاسترداد كلمة المرور.
- خطة التعلم: يدرس الشرائح 23-28، ويقارن رسائل الدخول، ثم يحلل السيناريوين الأول والثالث في ورقة العمل.
- زمن الوحدة: 30 دقيقة للمحتوى، و15 دقيقة للنشاط، و10 دقائق للتقويم، و5 دقائق للمشروع.
- معياري الإكمال: يقدم المتعلم رسالة موحدة وقرار تفويض خادمي ورسالة عامة لخطأ داخلي.



(Secure Logging) التسجيل الآمن

- ◀ التسجيل الآمن هو تصميم تسجيل أحداث التطبيق، خصوصاً الأحداث ذات الدلالة الأمنية، بما يدعم الرصد والتحقيق من دون كشف بيانات حساسة.
- ◀ يوفر رؤية تشغيلية وأمنية أعمق من سجلات البنية التحتية وحدها.
- ◀ **الوظيفة:** دعم الرصد والتحليل الآمن.
- ◀ **المسؤوليات:** تسجيل محاولات المصادقة، تسجيل إخفاقات التحقق، تسجيل إخفاقات الوصول، حماية السجلات، دعم التحليل، منع حقن السجل.
- ▶ **البروتوكولات والمعايير:** ASVS V7, OWASP Logging Cheat Sheet, OWASP Secure Coding Practices.
- ◀ **الأجهزة أو الأدوات:** خدمة سجل مركزية، محلل سجلات، تخزين محمي، تحقق نزاهة.
- ◀ **المخرج:** حدث أمني منظم أو تنبيه.
- ◀ **مثال:** يسجل فشل التفويض دون تسجيل رمز الجلسة.
- ◀ يُحفظ نوع الحدث والطابع الزمني ومعرف طلب بما يدعم التحقيق، مع حماية السجل ومنع حقن السجل أو الاعتماد على سجلات البنية وحدها.



التسجيل الآمن (Secure Logging) (الشكل)

SLIDE 29 · SECURE LOGGING

التسجيل الآمن



الأجهزة والأدوات

- خدمة سجل مركزية
- محلل سجلات
- تخزين محمي
- تحقق نزاهة

البروتوكولات والمعايير

- ASVS V7
- OWASP Logging Cheat Sheet
- OWASP Secure Coding Practices

الوظائف الرئيسية

- دعم الرصد والتحليل الآمن
- تسجيل محاولات المصادقة
- تسجيل إخفاقات التحقق
- تسجيل إخفاقات الوصول
- حماية السجلات

يسجل فشل التفويض دون تسجيل رمز الجلسة

التسجيل الآمن هو تصميم تسجيل أحداث التطبيق، خصوصاً الأحداث ذات الدلالة الأمنية، بما يدعم الرصد والتحقيق من دون كشف بيانات حساسة



- ◀ البيانات المحظورة في السجلات هي بيانات لا ينبغي حفظها عندما لا تكون لازمة لغرض تشغيلي أو أمني مشروع.
- ◀ يقلل هذا القرار أثر اختراق السجلات ويحمي الخصوصية والأسرار والجلسات.
- ◀ **الوظيفة:** تقليل البيانات الحساسة المحتفظ بها.
- ◀ **المسؤوليات:** منع كلمات المرور، منع معرفات الجلسات، منع تفاصيل النظام غير اللازمة، تقليل البيانات، حماية ما يلزم تسجيله.
- ◀ **البروتوكولات والمعايير:** ASVS V7، ASVS V8، نظام حماية البيانات الشخصية السعودي.
- ◀ **الأجهزة أو الأدوات:** مرشحات سجل، مكتبة تسجيل مركزية، سياسة احتفاظ، ضوابط وصول.
- ◀ **المخرج:** سجل منقح أو مقنع.
- ◀ **مثال:** يقنع المعارف الشخصي عند الحاجة إلى التتبع.
- ◀ تمر أحداث المنصة عبر تنقية تستبعد كلمات المرور ورموز الجلسات وتفاصيل النظام غير اللازمة، ثم تُحفظ في مستودع محمي.
- ◀ يقلل ذلك أثر اختراق السجلات مع الإبقاء على أثر تشغيلي مفيد.



البيانات المحظورة في السجلات (الشكل)

SLIDE 30 · ELEMENT

البيانات المحظورة في السجلات



المخرج المتوقع

- سجل منقح أو مقنع

الأجهزة والأدوات

- مرشحات سجل
- مكتبة تسجيل مركزية
- سياسة احتفاظ
- ضوابط وصول

الوظائف الرئيسية

- تقليل البيانات الحساسة المحتفظ بها
- منع كلمات المرور
- منع معرفات الجلسات
- منع تفاصيل النظام غير اللازمة
- تقليل البيانات

يقنع المعرف الشخصي عند الحاجة إلى التتبع
البيانات المحظورة في السجلات هي بيانات لا ينبغي حفظها عندما لا تكون لازمة لغرض تشغيلي أو أمني مشروع.

سجل قرارات رسائل الخطأ والتسجيل الآمن



المستند: سجل قرارات رسائل الخطأ والتسجيل الآمن

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم المبرني: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

سجل قرارات رسائل الخطأ والتسجيل الآمن

سياسة تشغيلية تعليمية لمنصة مواعيد طبية، مراجعة بتاريخ 11-05-2026

الحدث أو عنصر البيانات	قرار العرض للمستخدم	قرار التسجيل	الحماية أو التقيع المطلوب	مبرر القرار
فشل تسجيل الدخول بسبب اسم مستخدم غير مسجل	إظهار: تعذر تسجيل الدخول، تحقق من البيانات المدخلة.	تسجيل نوع الحدث والطابع الزمني ومعرف طلب عشوائي فقط.	لا يسجل اسم المستخدم كاملاً في سجل التطبيق التشغيلي.	منع تعدد الحسابات مع إتاحة التنوع التشغيلي.
فشل تسجيل الدخول بسبب كلمة مرور غير صحيحة	إظهار الرسالة الموحدة نفسها المستخدمة عند عدم وجود الحساب.	تسجيل نوع الحدث والطابع الزمني ومعرف طلب عشوائي فقط.	يحظر تسجيل كلمة المرور أو أي جزء منها.	حماية بيانات الاعتماد ومنع كشف وجود الحسابات.
طلب عرض موعد طبي	لا تعرض الواجهة إلا بيانات الموعد المصرح بها للمستخدم الحالي.	تسجيل معرف المستخدم الداخلي المقنع ومعرف العملية والطابع الزمني ونتيجة التفويض.	تقيع المعرف الشخصي وعدم تسجيل الملاحظات الطبية أو سبب الزيارة.	التمتع الأمني مع تقليل معالجة البيانات الشخصية والحساسية.
خطأ داخلي في قاعدة البيانات	إظهار: تعذر إتمام الطلب حالياً، حاول لاحقاً أو تواصل مع الدعم.	تسجيل رمز خطأ داخلي ومعرف طلب ومكون الخدمة دون نص الاستعلام أو بيانات الاتصال.	يحظر عرض أو تسجيل كلمات مرور قاعدة البيانات ومفاتيح الاتصال والاستعلامات التي تتضمن بيانات شخصية.	منع كشف البنية الداخلية والأسرار للمستخدم أو في السجلات.
رفع ملف مرفوض بسبب الحجم	إظهار: لا يمكن رفع الملف لأن حجمه يتجاوز خمسة ميجابايت.	تسجيل نوع الملف المعلن والحجم ومعرف العملية ونتيجة الرفض.	لا يسجل اسم الملف الأصلي إذا احتوى اسماً شخصياً، ويستبدل بمعرف ملف عشوائي.	توفير رسالة إرشادية دون الاحتفاظ ببيانات غير لازمة.
رمز مصادقة متعددة العوامل	لا يعرض إلا حفل إدخال الرمز ورسالة انتهاء صلاحية عامة.	لا يسجل الرمز أو قيمته أو الرسالة المرسل.	يحظر تسجيل الرمز المؤقت ووجهة الإرسال التفصيلية.	الرمز المؤقت من بيانات الاعتماد التي قد تسمح بالوصول للحساب.
رقم الهوية الوطنية والبريد الإلكتروني	لا يظهران في رسائل الخطأ.	يسجلان فقط عند وجود حاجة تشغيلية موثقة وبصورة مضمّنة.	يظهر جزء محدود من القيمة وفق سياسة التقيع، ولا تسجل القيمة الكاملة في سجلات الأخطاء.	تقليل البيانات وحماية الخصوصية وفق نظام حماية البيانات الشخصية السعودي.

تفصل السجلات عبر قناة مشفرة إلى مستودع مركزي محمي، وتخضع صلاحية قراءتها لأقل الامتيازات.

مستند تعليمي إداري، الأسماء والأرقام غير حقيقية

- أبدأ بقراءة عمود قرار العرض للمستخدم، ثم قارنه بقرار التسجيل والحماية المطلوبة.
- عند فشل الدخول تسجل المنصة نوع الحدث والطابع الزمني ومعرف طلب عشوائي فقط.
- وعند رفض ملف يتجاوز خمسة ميجابايت، تظهر رسالة إرشادية ولا يسجل اسم الملف الأصلي إذا احتوى اسماً شخصياً.



مصفوفة قرار التسجيل الآمن

الحدث أو البيانات	العرض للمستخدم	التسجيل	الحماية
فشل تسجيل الدخول	رسالة موحدة	نوع الحدث وطابع زمني ومعرف طلب	منع اسم المستخدم الكامل
خطأ قاعدة البيانات	رسالة عامة	رمز خطأ داخلي ومعرف طلب ومكون خدمة	منع الأسرار والاستعلامات الحساسة
رفع ملف أكبر من خمسة ميغابايت	رسالة حجم واضحة	نوع الملف المعلن والحجم ومعرف العملية ونتيجة الرفض	استبدال الاسم بمعرف عشوائي
رمز العامل الثاني	حقل إدخال فقط	لا تسجل القيمة	حظر الرمز ووجهة الإرسال

يحقق الجدول التوازن بين التتبع التشغيلي وتقليل البيانات الشخصية.



- ◀ خصص 15 دقيقة لمعالجة حالتين من ورقة العمل.
- ◀ في الحالة الأولى، اكتب الرسالة الموحدة للمستخدم وحدد البيانات الدنيا التي تسجل.
- ◀ في الحالة الثانية، اكتب قرار تفويض خادمي يمنع تعديل موعد لا يخص المستخدم الحالي.
- ◀ تحقق ذاتياً من أن الحل لا يعتمد على إخفاء زر في الواجهة، ولا يعرض تفاصيل داخلية أو بيانات اعتماد.



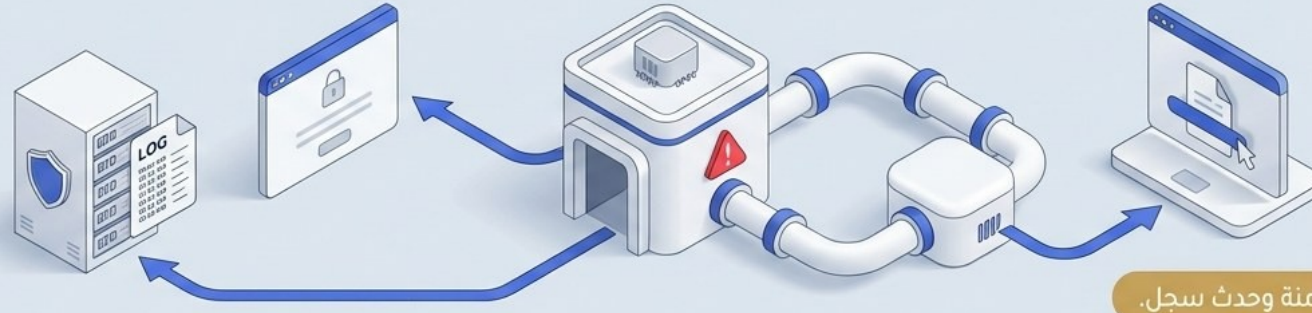
- ◀ إدارة الأخطاء الأمنية هي معالجة حالات الفشل والاستثناءات، بما فيها فشل الضوابط، بطريقة متسقة وآمنة.
- ◀ تحفظ التطبيق في حالة آمنة وتمنع كشف التفاصيل أو منح وصول عند فشل الضابط.
- ◀ **الوظيفة:** تحقيق رفض آمن عند الإخفاق.
- ◀ **المسؤوليات:** معالجة مركزية، رفض افتراضي، فصل رسالة المستخدم، تسجيل الاستثناء، اختبار مسار الخطأ.
- ▶ **البروتوكولات والمعايير:** ASVS V7, OWASP Error Handling Cheat Sheet, Secure by Design Section 4.2.
- ◀ **الأجهزة أو الأدوات:** معالج استثناءات، نظام تسجيل، اختبارات أخطاء، صفحات مخصصة.
- ◀ **المخرج:** استجابة خطأ آمنة وحدث سجل.
- ◀ **مثال:** ترفض المنصة ملفاً غير صالح وتظهر رسالة عامة للفريق غير المخول.
- ◀ يبقى الرفض هو السلوك الافتراضي عند فشل الضابط، فلا يُمنح وصول بسبب خطأ داخلي، وتُفصل رسالة المستفيد عن التفاصيل الفنية المسجلة للفريق المخول.



إدارة الأخطاء الأمنية (Security Error Handling) (الشكل)

SLIDE 33 · SECURITY ERROR HANDLING

إدارة الأخطاء الأمنية



الأجهزة والأدوات

- معالج استثناءات
- نظام تسجيل
- اختبارات أخطاء
- صفحات مخصصة

البروتوكولات والمعايير

- ASVS V7
- OWASP Error Handling Cheat Sheet
- Secure by Design Section 4.2

الوظائف الرئيسية

- تحقيق رفض آمن عند الإخفاق
- معالجة مركزية
- رفض افتراضي
- فصل رسالة المستخدم
- تسجيل الاستثناء

ترفض المنصة ملفاً غير صالح وتظهر رسالة عامة للفريق غير المخول.

إدارة الأخطاء الأمنية هي معالجة حالات الفشل والاستثناءات، بما فيها فشل الضوابط، بطريقة متسقة وآمنة.



- ◀ التعامل مع حوادث التطبيق هو تنظيم الاستجابة للأحداث أو الثغرات التي تؤثر في التطبيق بعد اكتشافها.
- ◀ يهدف إلى تقليل الأثر وإصلاح السبب ومنع التكرار في الإصدارات اللاحقة.
- ◀ **الوظيفة:** تحويل الحدث إلى إصلاح موثق.
- ◀ **المسؤوليات:** استقبال البلاغ، فرز الأثر، احتواء الحدث، إصلاح السبب، اختبار الإصلاح، توثيق الدروس، إبلاغ الأطراف عند انطباق الالتزامات.
- ◀ **البروتوكولات والمعايير:** NIST SSDF، نظام حماية البيانات الشخصية السعودي.
- ◀ **الأجهزة أو الأدوات:** سجل حوادث، نظام تتبع عيوب، سجلات أمنية، خطة استجابة.
- ◀ **المخرج:** تذكرة حادث وخطة معالجة ونتيجة إعادة اختبار.
- ◀ **مثال:** يوقف الفريق مسار رفع متأثراً ثم يصلح التحقق ويعيد الاختبار قبل النشر.
- ◀ يُوثق السبب الجذري والدروس المستفادة، ويُبلّغ الأطراف عند انطباق التزامات حماية البيانات الشخصية، حتى لا يُكتفى بمعالجة العرض الظاهر للخلل.



(الشكل) (Application Incident Handling) التعامل مع حوادث التطبيق

SLIDE 34 · APPLICATION INCIDENT HANDLING

التعامل مع حوادث التطبيق



المخرج المتوقع

- تذكير حادث وخطة معالجة ونتيجة إعادة اختبار

الأجهزة والأدوات

- سجل حوادث
- نظام تتبع عيوب
- سجلات أمنية
- خطة استجابة

الوظائف الرئيسية

- تحويل الحدث إلى إصلاح موثق
- استقبال البلاغ
- فرز الأثر
- احتواء الحدث
- إصلاح السبب

يوقف الفريق مسار رفع متأثراً ثم يصلح التحقق ويعيد الاختبار قبل النشر

التعامل مع حوادث التطبيق هو تنظيم الاستجابة للأحداث أو الثغرات التي تؤثر في التطبيق بعد اكتشافها



الوحدة الخامسة، التسجيل والخصوصية والاستجابة



- أهداف الوحدة: يحل المتعلم قرار تسجيل حدث أمني، ويوازن بين الرصد وتقليل البيانات، ويقترح معالجة موثقة لحادث تطبيق.
- خطة التعلم: يدرس الشرائح 29-34، ويقرأ سجل القرارات، ثم يصنف عناصر سجل تطبيق إلى مسموح ومحظور ومقنّع.
- زمن الوحدة: 30 دقيقة للمحتوى، و15 دقيقة للنشاط، و10 دقائق للتقويم، و5 دقائق للمشروع.
- معياري الإكمال: يبرر المتعلم سبب حظر كلمة المرور ورمز الجلسة، وسبب تقنّع المعرف الشخصي عند الحاجة.



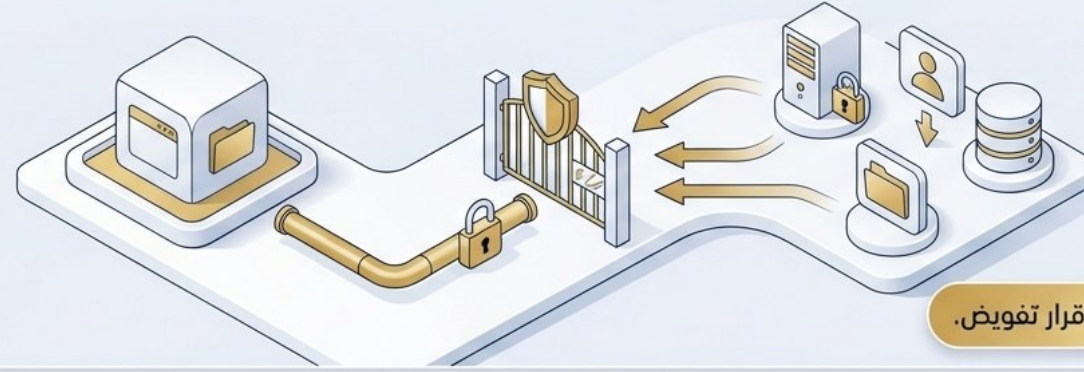
- ◀ أقل الامتيازات التشغيلية هو منح مكونات التطبيق وحساباته وعملياته أقل صلاحية لازمة للمهمة المعتمدة.
- ◀ يقلل هذا المبدأ أثر اختراق حساب أو خدمة ويحد من نطاق الضرر المحتمل.
- ◀ **الوظيفة:** تقليل أثر الاختراق.
- ◀ **المسؤوليات:** فصل الحسابات، تحديد الصلاحيات، مراجعة الامتيازات، إلغاء غير اللازم، حماية الحسابات الإدارية، توثيق الاستثناءات.
- ▶ **البروتوكولات والمعايير:** ASVS V4, Anderson Chapter 6 Access Control.
- ◀ **الأجهزة أو الأدوات:** إدارة هوية، أدوار خدمة، سياسات وصول، سجلات تدقيق.
- ◀ **المخرج:** مصفوفة صلاحيات وقرار تفويض.
- ◀ **مثال:** يكتب حساب رفع الملفات في مساحة محددة ولا يدير حسابات المستخدمين.
- ◀ تُراجع الامتيازات دورياً وتُلغى الصلاحيات غير اللازمة، مع حماية الحسابات الإدارية وتوثيق أي استثناء، لتقليل نطاق الضرر إذا اخترقت خدمة واحدة.



أقل الامتيازات التشغيلية (Operational Least Privilege) (الشكل)

SLIDE 35 · OPERATIONAL LEAST PRIVILEGE

أقل الامتيازات التشغيلية



مثال تطبيقي

- يكتب حساب رفع الملفات في مساحة محددة ولا يدير حسابات المستخدمين

المخرج المتوقع

- مصفوفة صلاحيات وقرار تفويض

الوظائف الرئيسة

- تقليل أثر الاختراق
- فصل الحسابات
- تحديد الصلاحيات
- مراجعة الامتيازات
- إلغاء غير اللازم

يكتب حساب رفع الملفات في مساحة محددة ولا يدير حسابات المستخدمين.

أقل الامتيازات التشغيلية هو منح مكونات التطبيق وحساباته وعملياته أقل صلاحية لازمة للمهمة المعتمدة.



- ◀ المصادقة متعددة العوامل استخدام أكثر من عامل للتحقق من هوية المستخدم، خصوصاً في العمليات الحساسة.
- ◀ تزيد الثقة في المصادقة وتقلل أثر الاعتماد على عامل واحد.
- ◀ **الوظيفة:** تقوية التحقق من الهوية.
- ◀ **المسؤوليات:** تحديد العمليات الحساسة، اختيار عامل إضافي، حماية دورة حياة العامل، دعم الاسترداد الآمن، تسجيل الأحداث، اختبار قابلية الاستخدام.
- ▶ **البروتوكولات والمعايير:** ASVS V2, OWASP Authentication Cheat Sheet.
- ◀ **الأجهزة أو الأدوات:** خدمة هوية، تطبيق عامل ثانٍ، رمز أمني، وسيلة تحقق معتمدة.
- ◀ **المخرج:** طلب تحد إضافي وقرار تحقق وسجل مصادقة.
- ◀ **مثال:** تطلب المنصة عاملاً إضافياً قبل تعديل بيانات حساسة.
- ◀ يُحمى رمز العامل طوال دورة حياته، ويُدعم الاسترداد الآمن، ويُسجّل حدث المصادقة من دون حفظ قيمة الرمز أو وجهة الإرسال التفصيلية.



المصادقة متعددة العوامل (Multi-Factor Authentication) (الشكل)

SLIDE 36 · MULTI-FACTOR AUTHENTICATION

المصادقة متعددة العوامل



البروتوكولات والمعايير

- ASVS V2
- OWASP Authentication Cheat Sheet

مثال تطبيقي

- تطلب المنصة عاملاً إضافياً قبل تعديل بيانات حساسة

الوظائف الرئيسية

- تقوية التحقق من الهوية
- اختيار عامل إضافي
- تحديد العمليات الحساسة
- حماية دورة حياة العامل
- دعم الاسترداد الآمن
- اختيار عامل إضافي

تطلب المنصة عاملاً إضافياً قبل تعديل بيانات حساسة.
المصادقة متعددة العوامل. استخدام أكثر من عامل للتحقق من هوية المستخدم، خصوصاً في العمليات الحساسة. تزيد الثقة في المصادقة وتقلل أثر الاعتماد على عامل واحد.



- ◀ مراجعة الشفرة فحص منظم للشفرة والتغييرات للتحقق من توافقها مع المتطلبات والضوابط الأمنية.
- ◀ تساعد على اكتشاف عيوب التصميم أو التنفيذ قبل وصولها إلى الإنتاج.
- ◀ **الوظيفة:** كشف العيوب قبل الدمج والنشر.
- ◀ **المسؤوليات:** مراجعة التغييرات الحساسة، التحقق من المدخلات، فحص الأسرار، مراجعة الاعتماديات، توثيق الملاحظات، متابعة الإصلاح.
- ▶ **البروتوكولات والمعايير:** NIST SSDF, OWASP Secure Coding Practices, OWASP ASVS.
- ◀ **الأجهزة أو الأدوات:** طلبات دمج، قوائم تحقق، تحليل ساكن، نظام تتبع ملاحظات.
- ◀ **المخرج:** تقرير مراجعة وقرار قبول أو رفض.
- ◀ **مثال:** ترفض المراجعة رسالة خطأ تكشف معرف جلسة.
- ◀ تغطي المراجعة التحقق من المدخلات وفحص الأسرار والاعتماديات، لا أسلوب الشفرة وحده، وتتابع عناصر الإصلاح قبل قبول طلب الدمج.



مراجعة الشفرة (Code Review) (الشكل)

SLIDE 37 · CODE REVIEW

مراجعة الشفرة



الأجهزة والأدوات

- طلبات دمج
- قوائم تحقق
- تحليل ساكن
- نظام تتبع ملاحظات

البروتوكولات والمعايير

- NIST SSDF
- OWASP Secure Coding Practices
- OWASP ASVS

الوظائف الرئيسية

- كشف العيوب قبل الدمج والنشر
- مراجعة التغييرات الحساسة
- التحقق من المدخلات
- فحص الأسرار
- مراجعة الاعتماديات

ترفض المراجعة رسالة خطأ تكشف معرف جلسة.

مراجعة الشفرة فحص منظم للشفرة والتغييرات للتحقق من توافقها مع المتطلبات والضوابط الأمنية. تساعد على اكتشاف عيوب التصميم أو التنفيذ قبل وصولها إلى الإنتاج.



- ◀ الاختبار الأمني المستمر هو دمج أنشطة التحقق الأمني بصورة متكررة ضمن تطوير وإصدار البرمجيات.
- ◀ يكشف الانحرافات والثغرات مبكراً، ويؤكد استمرار فاعلية الضوابط بعد كل تغيير.
- ◀ **الوظيفة:** تقديم دليل متكرر على سلامة الضوابط.
- ◀ **المسؤوليات:** تحديد الاختبارات، تشغيلها بعد التغييرات، فرز النتائج، معالجة العيوب، إعادة الاختبار، حفظ الأدلة.
- ◀ **البروتوكولات والمعايير:** NIST SSDF, OWASP ASVS.
- ◀ **الأجهزة أو الأدوات:** اختبارات وحدات وتكامل، فحص شفرة، فحص اعتماديات، مسار CI/CD، قائمة تحقق ASVS.
- ◀ **المخرج:** نتيجة اختبار وعيب موثق ودليل إعادة اختبار.
- ◀ **مثال:** يعاد اختبار رفض مدخل غير متوقع بعد تعديل وظيفة رفع الملفات.
- ◀ تُفرز النتائج وتُعالج العيوب ويُحفظ دليل إعادة الاختبار، ولا يُتجاهل إنذار عالي الخطورة لتسريع الإصدار من دون قرار خطر موثق.



الاختبار الأمني المستمر (Continuous Security Testing) (الشكل)

SLIDE 38 • CONTINUOUS SECURITY TESTING

الاختبار الأمني المستمر



المخرج المتوقع

- نتيجة اختبار وعيب موثق ودليل إعادة اختبار

الأجهزة والأدوات

- اختبارات وحدات وتكامل
- فحص شفرة
- فحص اعتماديات
- مسار CI/CD
- قائمة تحقق ASVS

الوظائف الرئيسية

- تقديم دليل متكرر على سلامة الضوابط
- تحديد الاختبارات
- تشغيلها بعد التغييرات
- فرز النتائج
- معالجة العيوب

يعاد اختبار رفض مدخل غير متوقع بعد تعديل وظيفة رفع الملفات.

الاختبار الأمني المستمر هو دمج أنشطة التحقق الأمني بصورة متكررة ضمن تطوير وإصدار البرمجيات.



- ◀ خصوصية البيانات الشخصية تعني حماية بيانات الأفراد وحقوقهم وتحديد التزامات جهات التحكم عند معالجتها.
- ◀ توجه المصمم إلى تحديد غرض المعالجة وتقليل البيانات وحمايتها وضبط الوصول إليها.
- ◀ **الوظيفة:** حماية خصوصية المستفيد وثقته.
- ◀ **المسؤوليات:** تحديد غرض المعالجة، تقليل البيانات، حماية البيانات، مراعاة الحقوق، ضبط الوصول، إعداد إشعارات جمع مناسبة.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية السعودي، OWASP ASVS V8.
- ◀ **الأجهزة أو الأدوات:** سجل بيانات، ضوابط وصول، تشفير، إخفاء أو ترميز، سجلات معالجة.
- ◀ **المخرج:** إشعار خصوصية وسجل معالجة وقرار جمع بيانات.
- ◀ **مثال:** تجمع منصة المواعيد أقل بيانات لازمة مع بيان غرض الجمع.
- ◀ لا تظهر الهوية الوطنية أو البريد في رسائل الخطأ، ويُضبط الوصول إلى البيانات الصحية المحدودة وفق غرض المعالجة المعلن.



خصوصية البيانات الشخصية (Personal Data Privacy) (الشكل)



SLIDE 39 · PERSONAL DATA PRIVACY

خصوصية البيانات الشخصية



مثال تطبيقي

- تجمع منصة المواعيد أقل بيانات لازمة
مع بيان غرض الجمع

المخرج المتوقع

- إشعار خصوصية وسجل معالجة وقرار
جمع بيانات

الوظائف الرئيسية

- حماية خصوصية المستفيد وثقته
- تحديد غرض المعالجة
- تقليل البيانات
- حماية البيانات
- مراعاة الحقوق

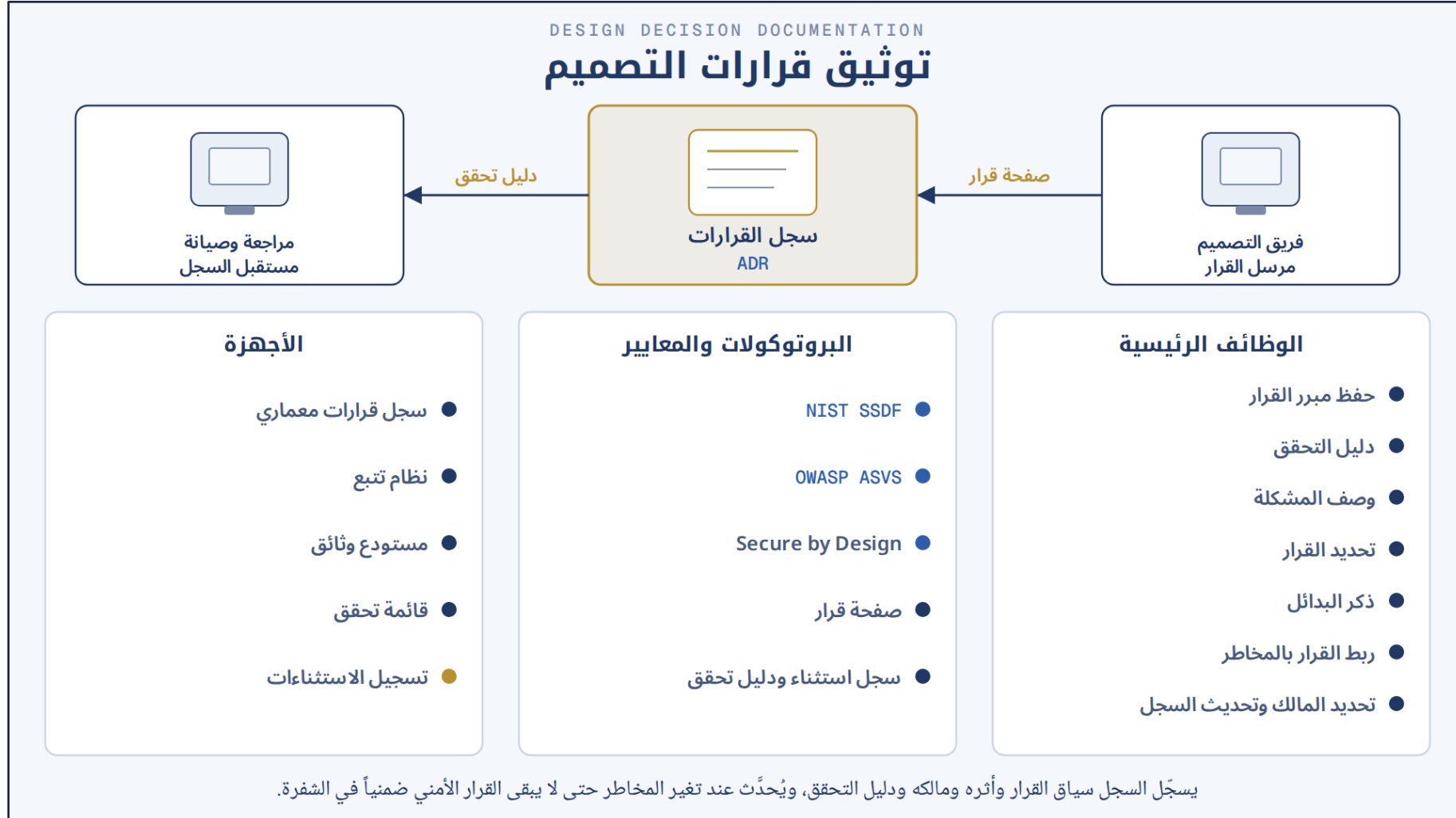
خصوصية البيانات الشخصية تعني حماية بيانات الأفراد وحقوقهم وتحديد التزامات جهات التحكم عند معالجتها.



- ◀ توثيق قرارات التصميم سجل يوضح القرار الأمني وسياقه وبدائله ومبرره وأثره وطريقة التحقق.
- ◀ يتيح التتبع والمراجعة والصيانة عندما تتغير المخاطر أو المتطلبات.
- ◀ **الوظيفة:** حفظ مبرر القرار ودليل التحقق.
- ◀ **المسؤوليات:** وصف المشكلة، تحديد القرار، ذكر البدائل، ربط القرار بالمخاطر، تحديد المالك، تسجيل الاستثناءات، تحديث السجل.
- ▶ **البروتوكولات والمعايير:** NIST SSDF, OWASP ASVS, Secure by Design.
- ◀ **الأجهزة أو الأدوات:** سجل قرارات معماري، نظام تتبع، مستودع وثائق، قائمة تحقق.
- ◀ **المخرج:** صفحة قرار وسجل استثناء ودليل تحقق.
- ◀ **مثال:** يوثق الفريق اختيار رسالة موحدة ورفض بديل يكشف وجود الحساب.
- ◀ يسجل السجل سياق القرار وأثره ومالكه ودليل التحقق، ويُحدَّث عند تغير المخاطر حتى لا يبقى القرار الأمني ضمنيًا في الشفرة.



(الشكل) (Design Decision Documentation) توثيق قرارات التصميم





- ◀ خصص 15 دقيقة لإكمال مصفوفة من ثلاثة صفوف: فشل الدخول، وطلب عرض موعد طبي، ورفع ملف يتجاوز خمسة ميغابايت.
- ◀ حدد لكل صف قرار العرض، وقرار التسجيل، والحماية أو التقنيع، والمبرر.
- ◀ راجع إجابتك: هل يسجل حدث مفيد للتحقيق؟
- ◀ هل يمنع كلمات المرور ورموز الجلسات؟
- ◀ هل يقلل معالجة البيانات الشخصية غير اللازمة؟

[illegible]



عناصر خطة تطوير البرمجيات الآمنة

المرحلة	النشاط الأمني	المخرج القابل للتحقق	مسؤول المراجعة	دليل التحقق
التخطيط	قصاص مستخدم أمنية وتصنيف بيانات	متطلبات أمنية وسجل أصول أولي	مالك المنتج ومسؤول أمن المعلومات	مراجعة المتطلبات
التصميم	نمذجة التهديد وحدود الثقة	نموذج تهديد وضوابط معتمدة	مسؤول أمن المعلومات وفريق التطوير	مراجعة النموذج
التطوير	التحقق من المدخلات وإدارة الأسرار ومراجعة الأقران	طلبات دمج موثقة	فريق التطوير	نتائج المراجعة والفحوص
الاختبار	فحص ساكن واختبار صلاحيات ورسائل خطأ	تقرير نتائج وخطة معالجة	مسؤول أمن المعلومات	تقرير إعادة الاختبار
النشر والتشغيل	تسجيل آمن ومراقبة واستجابة للحوادث	دليل تشغيل وسجل قرارات	مالك المنتج ومسؤول أمن المعلومات	قرار نشر موثق

يستخدم الطالب الجدول لتحويل مراحل الخطة إلى مسؤوليات وأدلة مراجعة، وليس لوصف مراحل عامة فقط.



الوحدة السادسة، التحقق والتوثيق وخطة المشروع



- أهداف الوحدة: يقترح المتعلم خطة تطوير آمن مكتملة، ويقيم جاهزية الإصدار للنشر، ويوثق قراراً أمنياً وبديله المرفوض.
- خطة التعلم: يدرس الشرائح 35-46، ويتتبع المثال المحلول على النموذج، وينفذ الأنشطة الختامية ومرحلة المشروع.
- زمن الوحدة: 25 دقيقة للمحتوى، و10 دقائق للأنشطة، و10 دقائق للتقويم، و15 دقيقة للمشروع.
- معياري الإكمال: يسلم المتعلم ملحقاً يربط كل مرحلة بنشاط ومخرج ومسؤول ودليل تحقق.

مثال محلول على النموذج: خطة تطوير آمن لمنصة مواعيد



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شركة الحلول التقنية والخدمات الرقمية تطوير وإدارة المنصات الرقمية والخدمات السحابية جازان، المملكة العربية السعودية الرقم المبرسي: 300000000000003 - السجل التجاري: 1010000000 هاتف: 0500000000		
النموذج: خطة تطوير برمجيات آمنة لمنصة مواعيد طبية		
خطة تطوير برمجيات آمنة لمنصة مواعيد طبية		
المعمل:		
وصف النظام:		
نطاق الحماية:		
مرحلة التخطيط:		
مخرج التخطيط:		
مرحلة التصميم:		
مخرج التصميم:		
مرحلة التطوير:		
مخرج التطوير:		
مرحلة الاختبار:		
مخرج الاختبار:		
مرحلة النشر والتشغيل:		
مخرج التشغيل:		
مسؤول اعتماد قرارات التصميم:		
معايير الإيقاف قبل النشر:		
الخطة تعليمية لمنشأة سعودية، وتدعم دمج الأمن في دورة التطوير بدلاً من تأجيله إلى اختبار نهائي.		
مقدم الطلب	المسؤول	الاعتماد
مستند تعليمي إلكتروني: الأسماء والأرقام غير حقيقية		

المعطيات: العميل (منشأة سعودية) يقدم خدمات صحية
جامعية من خلال منصة ويب وتطبيق جوال لحجز المواعيد
وإدارتها.

تشمل البيانات بيانات شخصية وصحية محدودة.

المطلوب بناء خطة أمنية تغطي حسابات المستخدمين وواجهات
البرمجة والمرفقات وقاعدة البيانات ومفاتيح التطبيق وسجلات
الأحداث، وتحدد مخرجات قابلة للتحقق قبل النشر.

- ◀ يكتب الفريق وصف النظام ونطاق الحماية أولاً، ثم يضيف في التخطيط قصص المستخدم الأمنية وتصنيف البيانات ومتطلبات حماية البيانات الشخصية.
- ◀ مصدر هذه البيانات هو معطيات النموذج.
- ◀ القاعدة المطبقة هي تحويل المخاطر والضوابط إلى متطلبات قابلة للاختبار.
- ◀ **الناتج الجزئي هو نطاق محدد يمنع إغفال المرفقات أو المفاتيح أو السجلات.**

الخطوة 2 من 4: توثيق التصميم والتطوير



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شركة الحلول التقنية والخدمات الرقمية		
تطوير وإدارة المنصات الرقمية والخدمات السحابية جازان، المملكة العربية السعودية الرقم المبرسي: 3000000000000003 - السجل التجاري: 1010000000 هاتف: 0500000000		
النموذج: خطة تطوير برمجيات آمنة لمنصة مواعيد طبية		
خطة تطوير برمجيات آمنة لمنصة مواعيد طبية		
المعمل:	المعمل (منشأة سعودية) يقدم خدمات صحية جامعية	
وصف النظام:	منصة ويب وتطبيق جوال لحجز المواعيد الطبية وإدارتها، مع بيانات شخصية وصحية محدودة للمستخدمين.	
نطاق الحماية:	حسابات المستخدمين، وأجهز البرمجة، ملفات المرفقات، قاعدة بيانات المواعيد، مفاتيح التطبيق، سجلات الأحداث.	
مرحلة التخطيط:	صياغة قصص مستخدم أمنية، تصنيف البيانات الشخصية، وتحديد متطلبات الامتثال لنظام حماية البيانات الشخصية السعودي.	
مخرج التخطيط:	وثيقة متطلبات أمنية قابلة للاختيار وسجل أولي للأصول والبيانات الحساسة	
مرحلة التصميم:	إجراء نمذجة تهديد لتحديد حدود الثقة ومسارات البيانات وقرارات المصادقة والتفويض والعزل.	
مخرج التصميم:	نموذج تهديد مع ضوابط معتمدة لواجهات البرمجة والجلسات وتخزين المرفقات.	
مرحلة التطوير:	تطبيق تحقق المدخلات وترميز المخرجات وإدارة الأسرار في خزانة مخصصة ومراجعة أقران للتعديلات الحساسة.	
مخرج التطوير:		
مرحلة الاختبار:		
مخرج الاختبار:		
مرحلة النشر والتشغيل:		
مخرج التشغيل:		
مسؤول اعتماد قرارات التصميم:		
معايير الإيقاف قبل النشر:		
الخطة تعليمية لمنشأة سعودية، وتدعم دمج الأمن في دورة التطوير بدلاً من تأجيله إلى اختبار نهائي.		
مقدم الطلب	المسؤول	الاعتماد
مستند تعليمي إلكتروني، الأسماء والأرقام غير حقيقية		

- يسجل الفريق مخرج التخطيط بوثيقة متطلبات قابلة للاختبار وسجل أولي للأصول.
- ثم يملأ مرحلة التصميم بنموذج تهديد يحدد حدود الثقة ومسارات البيانات وقرارات المصادقة والتفويض والعزل.
- في التطوير يضيف التحقق من المدخلات وترميز المخرجات وخزنة الأسرار ومراجعة الأقران.
- الناتج الجزئي هو ربط كل ممارسة بمخرج يمكن مراجعته.

الخطوة 3 من 4: الاختبار والتشغيل



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شركة الحلول التقنية والخدمات الرقمية
تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم المبرسي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

خطة تطوير برمجيات آمنة لمنصة مواعيد طبية

المعمل:	المعمل (منشأة سعودية) يقدم خدمات صحية جامعية
وصف النظام:	منصة ويب وتطبيق جوال لحجز المواعيد الطبية وإدارتها، مع بيانات شخصية وصحية محدودة للمستخدمين.
نطاق الحماية:	حسابات المستخدمين، واجهات البرمجة، ملفات المرفقات، قاعدة بيانات المواعيد، مفاتيح التطبيق، سجلات الأحداث.
مرحلة التخطيط:	صياغة قصص مستخدم أمنية، تصنيف البيانات الشخصية، وتحديد متطلبات الامتثال لنظام حماية البيانات الشخصية السعودي.
مخرج التخطيط:	وثيقة متطلبات أمنية قابلة للاختيار وسجل أولي للأصول والبيانات الحساسة.
مرحلة التصميم:	إجراء نمذجة تهديد لتحديد حدود الثقة ومسارات البيانات وقرارات المصادقة والتفويض والعزل.
مخرج التصميم:	نموذج تهديد مع ضوابط معتمدة لواجهات البرمجة والجلسات وتخزين المرفقات.
مرحلة التطوير:	تطبيق تحقق المدخلات وترميز المخرجات وإدارة الأسرار في خزانة مخصصة ومراجعة أقران للتعديلات الحساسة.
مخرج التطوير:	طلبات دمج موزعة بنتائج مراجعة الشفرة وفحص الاعتماديات وفحص الأسرار المكشوفة
مرحلة الاختبار:	تشغيل فحص ساكن للشفرة واختبارات أمنية لواجهات البرمجة والتحقق من الصلاحيات ورسائل الخطأ
مخرج الاختبار:	تقرير نتائج الاختبار وخطة معالجة للنتائج عالية الخطورة قبل النشر
مرحلة النشر والتشغيل:	تفعيل التسجيل الآمن ومراقبة الأحداث وخطة الاستجابة لحوادث التطبيق ومراجعة دورية للصلاحيات.
مخرج التشغيل:	
مسؤول اعتماد قرارات التصميم:	
معايير الإيقاف قبل النشر:	

الخطة تعليمية لمنشأة سعودية، وتدعم دمج الأمن في دورة التطوير بدلاً من تأجيله إلى اختبار نهائي.

مقدم الطلب	المسؤول	الاعتماد
مستند تعليمي إلكتروني، الأسماء والأرقام غير حقيقية		

يوثق الفريق طلبات الدمج بنتائج مراجعة الشفرة وفحص الاعتماديات وفحص الأسرار المكشوفة.

ثم يسجل في الاختبار فحص الشفرة واختبارات واجهات البرمجة والصلاحيات ورسائل الخطأ.

ينتج عن ذلك تقرير نتائج وخطة معالجة للنتائج عالية الخطورة.

وفي التشغيل يفعل التسجيل الآمن ومراقبة الأحداث والاستجابة للحوادث ومراجعة الصلاحيات بصورة دورية.

الخطوة 4 من 4: اعتماد النشر

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم المبرسي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

النموذج: خطة تطوير برمجيات آمنة لمنصة مواعيد طبية

خطة تطوير برمجيات آمنة لمنصة مواعيد طبية

المعمل:	العمل (منشأة سعودية) يقدم خدمات صحية جامعية
وصف النظام:	منصة ويب وتطبيق جوال لحجز المواعيد الطبية وإدارتها، مع بيانات شخصية وصحية محدودة للمستخدمين.
نطاق الحماية:	حسابات المستخدمين، وأجهز البرمجة، ملفات المرفقات، قاعدة بيانات المواعيد، مفاتيح التطبيق، سجلات الأحداث.
مرحلة التخطيط:	صياغة قصص مستخدم أمنية، تصنيف البيانات الشخصية، وتحديد متطلبات الامتثال لنظام حماية البيانات الشخصية السعودي.
مخرج التخطيط:	وثيقة متطلبات أمنية قابلة للاختيار وسجل أولي للأصول والبيانات الحساسة.
مرحلة التصميم:	إجراء نمذجة تهديد لتحديد حدود الثقة ومسارات البيانات وقرارات المصادقة والتفويض والعزل.
مخرج التصميم:	نموذج تهديد مع ضوابط معتمدة لواجهات البرمجة والجلسات وتخزين المرفقات.
مرحلة التطوير:	تطبيق تحقق المدخلات وترميز المخرجات وإدارة الأسرار في خزانة مخصصة ومراجعة أقران للتعديلات الحساسة.
مخرج التطوير:	طلبات دمج مؤلفة بنتائج مراجعة الشفرة وفحص الاعتماديات وفحص الأسرار المكشوفة.
مرحلة الاختبار:	تشغيل فحص ساكن للشفرة واختبارات أمنية لواجهات البرمجة والتحقق من الصلاحيات ورسائل الخطأ.
مخرج الاختبار:	تقرير نتائج الاختبار وخطة معالجة للنتائج عالية الخطورة قبل النشر.
مرحلة النشر والتشغيل:	تفعيل التسجيل الآمن ومراقبة الأحداث وخطة الاستجابة لحوادث التطبيق ومراجعة دورية للصلاحيات.
مخرج التشغيل:	دليل تشغيل آمني وسجل قرارات التسجيل وقائمة اتصال الاستجابة للحوادث.
مسؤول اعتماد قرارات التصميم:	مالك المنتج مع مسؤول أمن المعلومات وممثل فريق التطوير.
معايير الإيقاف قبل النشر:	لا ينشر الإصدار عند وجود ثغرة عالية الخطورة غير معالجة أو سر مكشوف أو غياب اختبار الصلاحيات للوظائف الحساسة.

الخطة تعليمية لمنشأة سعودية، وتدعم دمج الأمن في دورة التطوير بدلاً من تأجيله إلى اختبار نهائي.

مقدم الطلب	المسؤول	الاعتماد
مستند تعليمي إلكتروني، الأسماء والأرقام غير حقيقية		

يكتمل النموذج بدليل تشغيل آمني وسجل قرارات التسجيل وقائمة اتصال الاستجابة للحوادث.

يعتمد القرار مالك المنتج ومسؤول أمن المعلومات وممثل فريق التطوير.

يطبق معيار الإيقاف قبل النشر عند وجود ثغرة عالية الخطورة غير معالجة، أو سر مكشوف، أو غياب اختبار صلاحيات للوظائف الحساسة.

النتاج هو قرار نشر موثق وقابل للمراجعة.

ورقة عمل قرارات الواجهة ورفع الملفات



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

ورقة عمل: قرار التصميم الآمن في واجهة منصة الخدمات الصحية

#	السيناريو	التهديد أو القصور	القرار الأمني النموذجي
1	تعرض صفحة الدخول رسالة: المستخدم غير موجود، عندما يكتب الزائر اسماً غير مسجل، ورسالة: كلمة المرور غير صحيحة، عندما يكون الاسم مسجلاً.	تسريب وجود الحسابات وتمكين تعداد المستخدمين.	توحيد الرسالة للمستخدم في الحالتين، وتسجيل الحدث بأقل قدر من البيانات، مع تقييد المحاولات والمصادقة متعددة العوامل.
2	تتحقق واجهة رفع المستند من أن اسم الملف ينتهي بالامتداد PDF فقط قبل حفظه.	الاعتماد على الامتداد الظاهري يسمح بملف محتواه الفعلي مختلف أو باسم مزدوج.	استخدام قائمة سماح للصيغ المعتمدة، وفحص نوع MIME والترويسة الفعلية، وحد الحجم، وتخزين الملف في موقع معزول غير قابل للتنفيذ.
3	تعرض صفحة خطأ فني نص الاستعلام الداخلي واسم خادم قاعدة البيانات للمستفيد.	كشف تفاصيل البنية الداخلية وبيانات قد تساعد على الاستهداف.	عرض رسالة عامة مع معرف طلب للدعم، وتسجيل رمز خطأ داخلي في مستودع سجلات محمي دون أسرار أو بيانات شخصية.
4	تطلب واجهة برمجة تعديل الموعد معرف الموعد من المتصفح، ثم تعدل السجل إذا كان المستخدم مسجلاً للدخول فقط.	كسر التحكم في الوصول لأن تسجيل الدخول لا يثبت أن الموعد يخص المستخدم الحالي.	تنفيذ تحقق تفويض في الخادم لكل طلب وربط المورد بالمستخدم أو بالدور المصرح له قبل القراءة أو التعديل.
5	يحفظ المطور مفتاح خدمة الإشعارات داخل ملف إعدادات مرفوع إلى مستودع الشفرة لتسهيل تشغيل التطبيق.	انكشاف سر تشغيلي يمكن استخدامه للوصول غير المصرح إلى خدمة خارجية.	نقل المفتاح إلى خزانة أسرار، ومنح الخدمة أقل امتيازات، وتشغيل فحص أسرار آلي ومنع دمج الشفرة عند اكتشاف قيمة حساسة.

الإجابات النموذجية تربط كل قرار بمبدأ المنع وتقليل التسريب، ولا تتضمن خطوات هجومية.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- ◀ اقرأ كل سيناريو قبل كشف القرار النموذجي.
- ◀ في الصف الأول، اختلاف رسالة الدخول يكشف وجود الحسابات.
- ◀ وفي الصف الثاني، الاعتماد على امتداد PDF فقط لا يثبت نوع المحتوى الفعلي.
- ◀ طبق على كل صف تسلسلاً ثابتاً: حدد القصور، اربطه بالتهديد، ثم اختر ضابطاً يحقق الرفض الآمن أو التفويض المركزي أو حماية الأسرار.



نشاط تطبيقي، قرار تسجيل الدخول



- ◀ تعرض المنصة رسالة «المستخدم غير موجود» عند إدخال اسم غير مسجل، ورسالة «كلمة المرور غير صحيحة» عند إدخال اسم مسجل.
- ◀ اكتب قراراً تصميمياً من ثلاثة أجزاء: نص الرسالة الموحدة، الحد الأدنى من بيانات التسجيل، وضابط إضافي يحد من إساءة الاستخدام.
- ◀ أكمل النشاط عندما تربط كل جزء بالتهديد الذي يعالجه.



إجابة النشاط: قرار تسجيل الدخول



- ◀ تكون الرسالة الموحدة: «تعذر تسجيل الدخول، تحقق من البيانات المدخلة».
- ◀ يسجل النظام نوع الحدث والطابع الزمني ومعرف طلب عشوائي فقط، ولا يسجل اسم المستخدم كاملاً في السجل التشغيلي.
- ◀ يطبق تقييد محاولات الدخول بعد خمس محاولات فاشلة متتالية، مع المصادقة متعددة العوامل للعمليات الحساسة.
- ◀ يعالج القرار تعداد الحسابات ويحافظ على التتبع التشغيلي.



نشاط تحليلي، سجل أحداث لمنصة المواعيد

- ◀ حل العناصر الآتية: كلمة مرور، رمز جلسة، رقم هوية وطنية، طابع زمني، معرف عملية، ونتيجة تفويض.
- ◀ صنف كل عنصر إلى مسموح أو محظور أو مقنع في سجل التطبيق.
- ◀ برر قرارك بجملة لكل عنصر.
- ◀ اكتمل النشاط عندما تميز بين ما يخدم التتبع الأمني وما يزيد معالجة البيانات الحساسة دون حاجة تشغيلية.



إجابة النشاط: سجل أحداث لمنصة المواعيد



- ◀ الطابع الزمني ومعرف العملية ونتيجة التفويض مسموحة لأنها تدعم التتبع والتحليل.
- ◀ كلمة المرور ورمز الجلسة محظوران لأنهما قد يسمحان بالوصول غير المصرح به.
- ◀ رقم الهوية الوطنية يقنع عند وجود حاجة تشغيلية موثقة، ولا تسجل قيمته كاملة في سجلات الأخطاء.
- ◀ يحقق هذا التصنيف تقليل البيانات مع الاحتفاظ بأحداث أمنية مفيدة.



مرحلة المشروع التراكمي، خطة البرمجيات الآمنة



للمشروع التراكمي، أعد ملحق خطة تطوير برمجيات آمنة للنظام المختار.

حدد خمس مراحل هي التخطيط والتصميم والتطوير والاختبار والتشغيل. اكتب لكل مرحلة نشاطاً أمنياً ومخرجاً قابلاً للتحقق ومالكاً للمراجعة. أضف قراراً واحداً لمواجهة آمنة، وقراراً للتسجيل، وقراراً لإدارة الأسرار، وخطة لمعالجة نتيجة عالية الخطورة قبل النشر.



تقويم ذاتي وخلاصة الوحدة السادسة



هل تشمل التخطيط والتصميم والتطوير والاختبار والنشر والتشغيل؟



راجع خطة مشروعك قبل التسليم المرحلي.



هل يوثق سجل القرار البديل المرفوض ومبرر الرفض؟



هل لكل مرحلة نشاط أمني ومخرج قابل للتحقق ومالك مراجعة؟



أوقف قرار النشر عند وجود ثغرة عالية الخطورة غير معالجة، أو سر مكشوف، أو غياب اختبار صلاحيات للوظائف الحساسة.





يحقّق تصميم الواجهات ورسائل الخطأ الموحدة الهدف الثاني
بتقليل التسريب مع دعم المستخدم.



يحقّق تطوير البرمجيات الآمنة الهدف الأول عندما يدمج المتطلبات
ونمذجة التهديد والتحقّق في مسار التسليم.



تحقّق خطة التطوير الموثقة الهدف الرابع بربط كل مرحلة بمخرج
ودليل تحقّق.



تحقّق إدارة الأخطاء والتسجيل الآمن الهدف الثالث عبر رفض آمن
وسجلات منقحة قابلة للتحليل.



تحقّق مصفوفة التسجيل وحماية البيانات الهدف الخامس بالموازنة بين الرصد وتقليل البيانات وحمايتها.





1. Souppaya, M., Scarfone, K., & Dodson, D. (2022). Secure Software Development Framework (SSDF) Version 1.1: NIST SP 800-218. NIST.
2. OWASP Foundation. (2021). OWASP Top 10:2021: The Ten Most Critical Web Application Security Risks.
3. OWASP Foundation. OWASP Application Security Verification Standard (ASVS).
4. OWASP Foundation. OWASP Secure Coding Practices: Quick Reference Guide.
5. OWASP Foundation. OWASP Cheat Sheet Series.
6. المملكة العربية السعودية. نظام حماية البيانات الشخصية، المرسومان الملكيَّان (م/19) و(م/148).
7. Anderson, R. (2020). Security Engineering (3rd ed.). Wiley.
8. Johnsson, D. B., Deogun, D., & Sawano, D. (2019). Secure by Design. Manning Publications.



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شكراً لكم

معهد البحوث والخدمات الاستشارية – جامعة جازان